

Ph.D. Dissertation



**Doctorate School in
Information and Communication Technology and Engineering**

Department of Engineering
University of Napoli Parthenope

**DATA TRUSTWORTHINESS IN CRITICAL INFRASTRUCTURES
PROTECTION**

Federica Uccello

XXXVI Cycle

Advisor: Prof. Salvatore D'Antonio

Coordinator: Prof. Agostino Iadicicco

Abstract

Critical Infrastructures (CIs) form the backbone of modern societies, ensuring the delivery of vital goods and services, and their disruption can have profound implications for both safety and security. Moreover, the emergence of Smart Infrastructures and the Internet of Things (IoT) has underscored the critical role of data in CIs, bringing new challenges for cybersecurity. This dissertation explores security challenges of CIs, especially against cyber-attacks targeting data, presenting solutions for security monitoring and data protection in CIs. The key contributions of this work include a literature review on Data Provenance in CIs, the development and validation of an Advanced Tamper-Resistant Storage (ATRS) framework, a Cyber-Attack Detection Framework (CADF), and the integration of both. Machine Learning (ML) techniques are employed to enhance CADF's accuracy in detecting attacks, featuring Association Rule Mining (ARM) and Explainable Artificial Intelligence (xAI), showing promising experimental results. This research seeks to enhance the resilience of critical infrastructures by providing a comprehensive solution and methodology for preventing and detecting data-centric cyber-attacks. By securing data and improving security monitoring, it offers a robust defense against threats that could otherwise have catastrophic consequences.

Acknowledgements

I would like to express my deepest gratitude to all those who have supported me on this remarkable journey of pursuing a Ph.D. It takes quite a bit of determination, some might say, even a touch of madness, especially after spending years studying engineering. But this journey would not have been possible without the assistance of the right people. I am deeply grateful to my colleagues at the Fitness Lab and the professors who stood by my side throughout this academic endeavor.

A special expression of gratitude goes to Salvatore D'Antonio and Luigi Coppolino, who have not only contributed to my professional growth but also instilled in me the belief in my own capabilities. They challenged me with tasks I never thought I could conquer and placed their unwavering trust in my abilities. I extend my heartfelt thanks to Enzo for always being there to rescue me from the stress of countless operational tests and demos, and life overall. I am appreciative of all the friends who provided their endless support and encouragement, both near and far. To my friends and colleagues in Bydgoszcz, your presence and the unique study abroad experience you shared with me enriched my life and allowed me to learn so much in such a short time.

Carl, your unconditional encouragement through every twist and turn in my journey has been invaluable. Words cannot explain how grateful I am for you being there for me, no matter the decisions I made, or where in the world I was. Finally, thanks to my family, and most especially to my mom. You are my idol, the embodiment of who I aspire to become. Your unconditional love and guidance have been the driving force behind my accomplishments, ever since I was a little kid in school. Thank you for seeing in me what I could not see, and pushing me in never giving up.

Federica Uccello

*It is better to deserve honors and not have them
than to have them and not to deserve them.*

– Mark Twain

Contents

List of Tables	vii
List of Figures	ix
List of Acronyms	xi
Introduction	1
1 Critical Infrastructures Protection	3
1.1 Threat Landscape in Critical Infrastructures	4
1.2 Security Information and Event Management System	6
1.2.1 Security Probes	7
1.2.2 Parsing and Normalization	7
1.2.3 Correlation Engine	7
1.2.4 Rule Editor	9
1.2.5 Log Storage	9
1.2.6 Monitoring	9
1.3 Role of Data Provenance in CI Security Monitoring	10
2 Background and Related Work	13
2.1 Data Provenance	13
2.1.1 Blockchain-Based Data Provenance	15
2.1.2 Data Provenance through Smart-Contracts	17
2.1.3 Other Technologies	20
2.2 Attack Detection	22
2.3 Machine Learning in Attack Detection	22
2.3.1 Association Rule Mining	23
2.3.2 Explainable Artificial Intelligence	24
3 The Advanced Tamper-Resistant Storage	25

3.1	Proposed Architecture	25
3.2	System Evaluation	28
3.2.1	Use Case	28
3.2.2	Performance Evaluation	30
4	The Cyber-Attack Detection Framework	33
4.1	Proposed Architecture	33
4.1.1	Message Collector	35
4.1.2	Message Adapter	35
4.1.3	Stream Processing Support	36
4.1.4	Real-Time Correlator	36
4.1.5	Rule Designer	37
4.1.6	Historical Database	37
4.1.7	Dashboard	37
4.2	Use Case and Validation	38
4.2.1	The CADF in the Space Sector	38
4.2.2	The CADF in the Energy Domain	39
5	The Hybrid Cyber-Attack Detection Framework	43
5.1	Rule Discovery	46
5.1.1	CADF Rules	46
5.1.2	ARM Rules	46
5.1.3	xAI Rules	47
5.2	Parameter Settings	48
5.2.1	Feature Selection Parameters	48
5.2.2	Association Rule Mining Parameters	49
5.2.3	Rules Parameters	49
5.3	Experimental Result	50
6	Application Domains and Use Cases	53
6.1	Anomaly Detection	53
6.1.1	Running Example	54
6.2	Intrusion Detection	55
6.2.1	Running Example	55
6.3	System Recovery	56
6.3.1	Running Example	57
6.4	Response Mechanisms	57
6.4.1	Running Example	59

7 Conclusion	61
Bibliography	63

List of Tables

3.1	Data Message frame organization according to the IEEE C37.118 standard	29
3.2	Cost Analysis for the creation of a provenance record. ^a	32
5.1	Most relevant features selected for the experiment.	45
5.2	Summary of classification reports for the original CADF rules.	50
5.3	Summary of classification reports for the ARM rules.	50
5.4	Summary of classification reports for the xAI rules.	51

List of Figures

1.1	Effects of Cyber-Attacks targeting data on the CIA triad	5
1.2	A reference Security Information and Event Management system architecture [1]	8
3.1	High-level architecture and data flow of the ATRS. The direction of the arrows indicate which component is receiving data and/or commands. . . .	27
3.2	PMU and Processing Unit command flow according to the IEEE C37.118 standard	30
3.3	Performance evaluation of the ATRS. The test was conducted by feeding input data of increasing size to the framework	31
3.4	Cost evaluation of the ATRS. The test was conducted by feeding input data of increasing size to the framework	32
4.1	Functionalities of the CADF in accordance to the proposed architecture of Security Monitoring framework for CIs.	34
4.2	High-level architecture and data flow of the CADF	35
4.3	Use case example for the CADF. A combined brute force and device alteration attack is detected.	39
5.1	Proposed approach for Hybrid CADF. A ML classifier is used to evaluate the accuracy of the CADF rules, and to define more advanced discriminatory criteria based on the analysis of results and hidden relationship between features.	44

List of Acronyms

ACL	Access Control Language
AI	Artificial Intelligence
ANOVA	Analysis of Variance
ARM	Association Rule Mining
ATRS	Advanced Tamper-Resistant Storage
BES	Bulk Electric Systems
BIM	Building Information Modeling
CADF	Cyber-Attack Detection Framework
CERT	Computer Emergency Response Team
CIA	Confidentiality Integrity and Availability
CI	Critical Infrastructure
CP-ABE	Ciphertext-Policy Attribute-based Encryption
CTI	Cyber threat information
DCS	Distributed Control Systems
DoS	Denial of Service
DDoS	Distributed Denial of Service
EDS	Energy Delivery Systems
FDIA	False Data Injection Attack

GDPR	General Data Protection Regulation
HTTP	Hypertext Transfer Protocol
IC	Integrated Circuit
ICS	Industrial Control Systems
IDMEF	Intrusion Detection Message Exchange Format
IDS	Intrusion Detection System
IDSA	International Data Spaces Association
IPC	Interprocess Communication
IPFS	InterPlanetary file storage system
IoT	Internet of Things
Man	in the Middle
ML	Machine Learning
MitM	Man in the Middle
NIST	National Institute of Standards and Technology
PBFT	Practical Byzantine Fault Tolerance
PDC	Phasor data concentrator
PMU	Phasor Measurement Unit
PoS	Proof of Stake
PoW	Proof of Work
PUF	Physically Unclonable Function
SCADA	Supervisory Control and Data Acquisition
SHA	Secure Hash Algorithm
SHAP	SHapley Additive exPlanations (SHAP)

SMOTE	Synthetic Minority Over-sampling Technique
SSI	Self-Sovereign Identity
TPM	Trusted Platform Module
TLS	Transport Layer Security
UIT	Universal Identifier of Things
VDR	Verifiable Data Registry
xAI	Explainable Artificial Intelligence

Introduction

In recent years, Critical Infrastructures (CIs) have become increasingly vulnerable to cyber-attacks. This is due to a number of factors, including the growing reliance of CIs on digital technologies and data, the increasing sophistication of cyber attacks, and the interdependencies between different CIs. In light of the growing threat of cyber-attacks, it is compulsory to develop and implement robust security measures to protect CIs. Data is essential in this context: large amounts of data are stored and collected continuously to monitor systems and networks, to make operational decisions, and to provide services to customers. The protection of data in CIs is therefore a highly critical task, as data constitutes one of the most targeted assets in cybercrime. Attackers may steal data to learn about the vulnerabilities of CI systems, or to manipulate them and disrupt the service provided, and data breaches can have a significant reputational and financial impact as well. However, protecting data in such an interconnected scenario is not trivial, especially in terms of ensuring reliability and traceability. To address these concerns, this Thesis collects a series of research and experimental results aiming at providing an extensive solution for security monitoring and data protection in CIs. The key contributions of the present work can be summarized as follows:

- Literature review on Data Provenance in CIs: to provide a better understanding of the current landscape, a rigorous survey has been conducted, with a focus on tamper-resistant storage techniques.
- Definition and implementation of a novel framework for tamper-resistant storage in CIs: the Advanced Tamper-Resistant Storage (ATRS) is a Blockchain-based tool designed to securely store data in a fully transparent fashion.
- Definition and implementation of an attack detection solution for CIs: the Cyber-Attack Detection Framework (CADF) has been developed to promptly detect known and novel attacks by monitoring systems and applications.
- Integration of the ATRS and the CADF: in order to provide an inclusive solution for CIs, the two solutions have been successfully integrated. When a CADF alert is

raised, all security relevant data is permanently stored in the ATRS. Two individual use cases are presented, considering attacks targeting Confidentiality and Integrity.

- Enhancement of the CADF through Machine Learning (ML): Artificial Intelligence (AI) has been employed to improve the accuracy of the CADF detection criteria, achieving near-perfection results. A novel use case is presented, focusing on threat against Availability.

The Thesis is organized as follows: Chapter 1 provides context and motivation behind the present work, emphasizing the need for integrated approaches and providing a reference architectural design for comprehensive real-time security monitoring, as well as highlighting the role of Data Provenance in CIs protection. Chapter 2 overviews the relatex work. In particular, a survey on Data Provenance application and techniques in CIs has been conducted. In addition, a state-of-the-art analysis of attack detection within CIs is presented. Chapter 3 showcases the conceptual architecture, implementation and testing of the ATRS; Chapter 4 shows the conceptual architecture, implementation and testing of the CADF; The ML-based CADF augmentation is presented in Chapter 5, including the proposed methodology, a brief overview of enabling technologies, and experimental results. Chapter 6 extends the validation presented in Chapter 3 and 4, discussing application domains and use cases for the proposed integrated solution. Finally, a Conclusion chapter ends the Thesis with some final remarks.

Chapter 1

Critical Infrastructures Protection

CIs are essential systems and networks that underpin the functioning of modern societies. The rapid advancement of technology has led to an increased reliance on critical systems across various domains, including aerospace, healthcare, transportation, and energy. These systems play a vital role in ensuring the smooth operation of crucial services and often involve human lives and significant financial implications. However, the complexity of these systems makes them susceptible to faults and security threats, which can have severe consequences. For an infrastructure to be considered critical, a disruption or incapacity to offer services would result in significant impacts on safety, security, health, and/or economics. The European Commission defines a CI as an asset or system that is needed for the maintenance of vital societal functions. Damage to CI, its destruction, or disruption by natural disasters, terrorism, criminal activity, or malicious behavior may have a significant negative impact on the security of the EU and the well-being of its citizens [2]. Industrial Control Systems (ICS) play a crucial role in delivering essential services within CIs. These systems consist of a group of control systems used for industrial protection, including SCADA (Supervisory Control and Data Acquisition) and DCS (Distributed Control Systems). In the past, ICSs were physically isolated from the outside world. However, with the benefits of interoperability, such as real-time monitoring, redundancy, and overall optimization, these systems are now connected to the corporate Wide Area Network and the Internet. Additionally, with the migration towards Smart Infrastructures through the deployment of the Internet of Things (IoT), data is now recognized as a crucial component of CIs. The needs and benefits of data-driven approaches have been highlighted by the European Commission in their European Data Strategy [3], underlying how this revolution also brings new challenges for cybersecurity. In particular, it is noted how the growing importance of data makes ICSs and CIs more vulnerable to attacks, making the protection of critical systems crucial.

1.1 Threat Landscape in Critical Infrastructures

Real-time dependability and security monitoring are critical aspects of maintaining the proper functioning of CIs. Dependability monitoring involves the continuous assessment of system performance and the detection of potential faults or failures; security monitoring focuses on identifying and mitigating security threats such as intrusions, data breaches, and malicious activities. The growing complexity of CIs in various domains has presented new challenges in ensuring their reliability and security. As these systems become more interconnected and technologically advanced, the potential risks associated with faults and security threats have increased significantly. Therefore, there is a pressing need for advanced monitoring techniques to address these challenges effectively. One of the key motivations behind the present research is the potential consequences of faults in critical systems. A fault can manifest in various ways, such as hardware failures, software glitches, or communication errors. In CIs, even a minor fault can have severe implications. Rapid detection and recovery mechanisms are needed to minimize the impact of faults and restore the system to its normal operation as quickly as possible. In addition to faults, CIs face a wide range of security threats. Attacks can be classified based on the attacker's objectives, which include compromising the fundamental requirements of data confidentiality, integrity, and availability (CIA triad).

- Data confidentiality - sensitive data can't be disclosed to unauthorized entities or processes.
- Data integrity - data can't be modified in an unauthorized way to prevent inappropriate alteration and/or destruction and guarantee authenticity and non-repudiation.
- Data availability - data must be accessible and usable by whoever is legitimated to do so.

Figure 1.1 shows examples of notable cyber-attacks aimed at disrupting the requirements mentioned above. It is important to note that while the figure shows a clear distinction between such attacks, the same attack can be used to violate multiple requirements. Examples of attacks targeting data confidentiality include Eavesdropping, an attack where the adversary captures small packets from the network transmitted by the victim, and reads the data content in search of information of interest. In Man in the Middle (MitM) attacks, the adversary secretly violates the communications between two parties who believe that they are directly communicating with each other, as the attacker has inserted themselves between the two parties. Phishing is among the most common attacks affecting data confidentiality: the adversary sends a fraudulent message

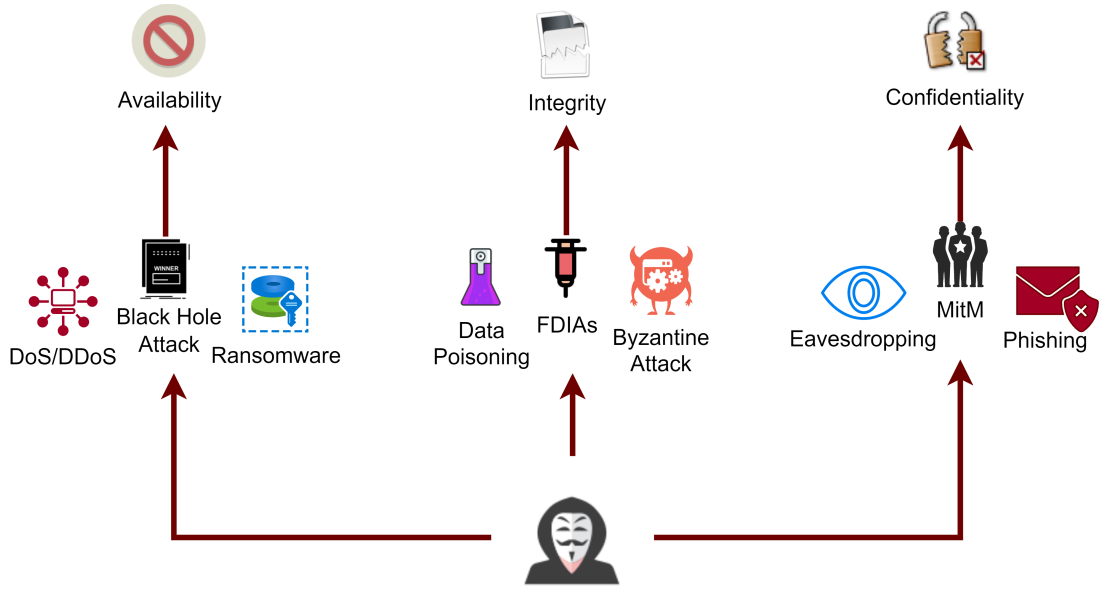


Figure 1.1: Effects of Cyber-Attacks targeting data on the CIA triad

designed to steal sensitive information from the victim, or tricking the victim into revealing them. When it comes to data integrity, common attacks include Data Poisoning, where the attacker compromise the training dataset of a ML model with false data to deceive it throughout the training phase. In False Data Injection Attacks (FDIAs), the adversary injects false data to disrupt the target's operation through compromised sensors. Another threat to integrity is posed by Byzantine Attack: The adversary gains full control of a genuine device and performs illogical behaviour to interrupt the system. Data availability is also heavily targeted by widely spread attacks, such as Denial of Service (DoS)/Distributed Denial of Service (DDoS), where single/multiple systems flood the target with a high volume of traffic (volumetric attack) or by targeting specific resources and exhausting them (non-volumetric attack). Black Hole Attacks, a malicious node uses its routing technique to promote itself for having the shortest route to the destination node. A further common attack threatening availability is Ransomware, malicious software designed to encrypt data until a ransom is paid.

These security threats can compromise sensitive data, disrupt system operations, or even facilitate further attacks. Real-time security monitoring plays a key role in identifying and mitigating these threats promptly, minimizing their impact, and preventing potential damage. Real-time monitoring becomes even more crucial in CI environments to detect and respond to security incidents promptly. The importance of ensuring the reliability and security of CIs cannot be overstated. Organizations and stakeholders recognize the potential consequences of system failures and security breaches, both in terms of financial

losses and damage to reputation. Therefore, there is a strong motivation to invest in research and develop effective monitoring techniques that can address the complexities and challenges of real-time reliability and security monitoring in critical systems.

1.2 Security Information and Event Management System

As technology advances and CIs become more interconnected, the value and vulnerability of data in these systems increase. Protecting data from cyber-attacks is not only about preserving the confidentiality, integrity, and availability of the information but also about safeguarding the critical functions that rely on it. Therefore, it is imperative to develop robust security strategies and solutions that focus on data protection within CIs. This includes implementing monitoring mechanisms to safeguard sensitive data and ensure its continuous availability. Moreover, solutions for detecting and responding to attacks targeting data within CIs should be a top priority, as these systems are high-value targets for adversaries. Detecting cyber-attacks within CIs is of prime importance because early identification of threats allows for timely response and mitigation. Developing solutions for detecting attacks is a critical component of a comprehensive security strategy for CIs. Given the interconnected and data-driven nature of modern CIs, it is essential to employ advanced security measures that go beyond traditional approaches: advanced detection systems can identify unusual data patterns and trigger alerts to operators or automated systems to take corrective actions promptly. It is also crucial to regularly update and fine-tune these detection solutions, as cyber threats constantly evolve. Continuous monitoring and improvement of detection capabilities are necessary to face new threats and attack patterns. Within real-time security monitoring, the role of Security Information and Event Management Systems (SIEM) has been subject of discussion and research in the last few years [4] [5] [6], highlighting the importance of early detection in the context of CIs in particular. The United States National Institute of Standards and Technology (NIST) defines a SIEM as an “application that provides the ability to gather security data from information system components and present that data as actionable information via a single interface” [7]. SIEM systems are able to collect and analyze log data from diverse sources, providing an overall view of the security landscape. In particular, a core functionality of SIEM lies in centralized log management. This includes consolidating logs from various sources across the network or system, creating a unified view that facilitates efficient log analysis. This unified perspective aids in the detection of security events and incidents, laying the foundation for a proactive security stance. SIEM systems feature real-time monitoring capabilities by continuously analyzing incoming data. The aim is to identify and address security incidents in their early stages, mitigating potential risks

before they escalate. Another key capability of SIEM systems is incident response. These systems provide comprehensive insights into the nature and scope of security incidents. In addition to real-time monitoring, this feature forms a defense mechanism against evolving cyber threats. In this section, a general architecture for SIEM in CIs, which constitutes a reference for the ATRS and CADF architectures, presented in chapter 3 and chapter 4 respectively, is proposed. The architecture is designed to provide a holistic approach to system protection by integrating fault tolerance measures and security mechanisms. It comprises several components that work together to detect, analyze, and respond to potential faults and security threats. The integration of these functional modules within the conceptual architecture enables the real-time monitoring, detection, and response to security incidents in critical systems. Each module contributes to the overall objective of ensuring the reliability and security of the system, providing a robust framework for protecting CI from potential faults and security threats. The functional modules are depicted in Figure 1.2 and explained in depth in the following.

1.2.1 Security Probes

The security probes module is in charge of data collection, by gathering events and information from various sources within the critical system. It includes data collection from sensors, logs, network traffic, and user interactions. The security probes ensure a continuous flow of data to the monitoring system, capturing relevant security-related events and activities.

1.2.2 Parsing and Normalization

The parsing and normalization module processes the collected data to ensure uniformity and consistency. It involves parsing the raw data and extracting relevant fields and attributes. This module also normalizes the data to a common format and structure, allowing integration and analysis across different data sources. The parsed and normalized data form a single stream with standardized attributes, facilitating effective analysis and correlation.

1.2.3 Correlation Engine

The Correlation Engine is a core component responsible for analyzing the processed data. It performs rule-driven correlation to detect security incidents and investigate potential threats. The engine compares the collected data against predefined rules and patterns to identify anomalous or suspicious behaviour. The Correlation Engine plays a significant role in identifying complex attack scenarios that may involve multiple events or data

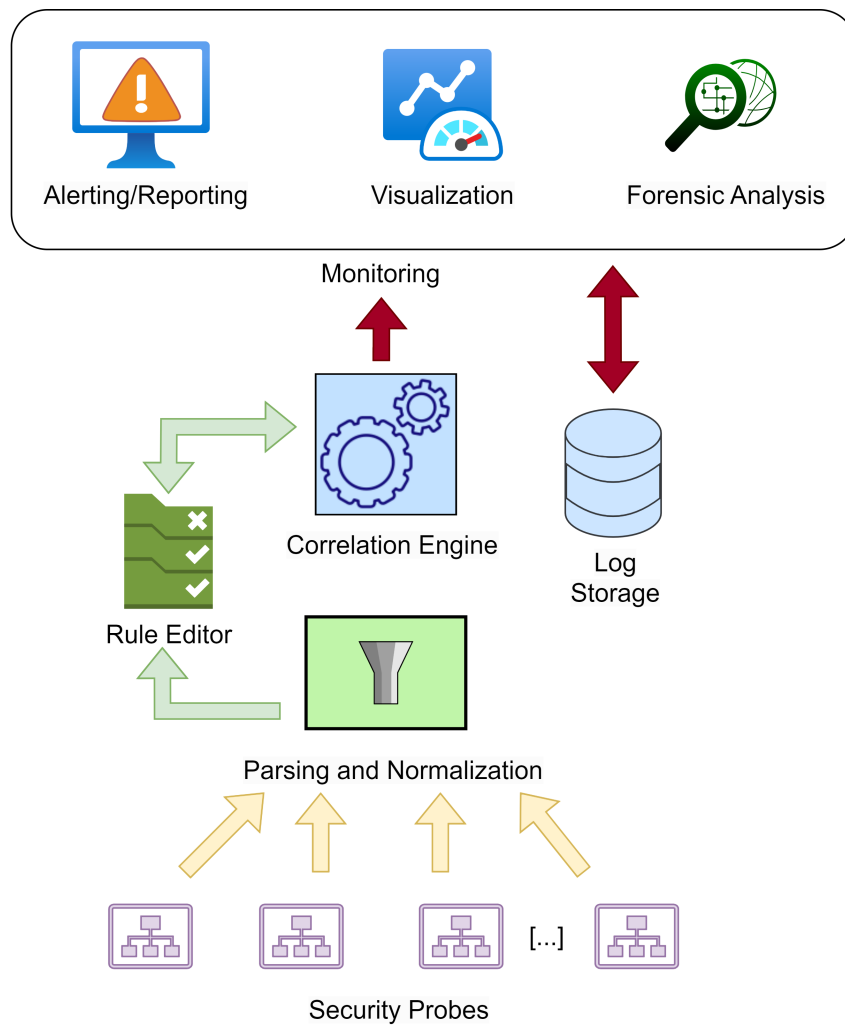


Figure 1.2: A reference Security Information and Event Management system architecture [1]

sources. It supports real-time monitoring and analysis, enabling timely detection and response to security incidents.

1.2.4 Rule Editor

The Rule Editor module provides a user-friendly interface that allows users to create, customize, and manage rules for security incident detection and analysis. It empowers security staff to define their own rules based on the specific requirements of the critical system. The Rule Editor offers a flexible and adaptable approach to security monitoring, enabling the system to adapt to changing threat landscapes and evolving system configurations.

1.2.5 Log Storage

The Log Storage module securely stores the collected and processed data for future analysis, auditing, and forensic purposes. It ensures that the logs are stored in a tamper-proof manner, maintaining the integrity and confidentiality of the information. The log storage module may employ encryption, access controls, and backup mechanisms to ensure the availability and protection of the stored logs. Compliance requirements and data protection regulations are considered during the design and implementation of this module.

1.2.6 Monitoring

The monitoring module encompasses several sub-modules that contribute to the ongoing analysis and response to potential security incidents.

Alerting

The alerting sub-module generates alerts and notifications to rapidly notify security staff of immediate issues or potential threats. It employs configurable alert rules and thresholds to trigger notifications based on the severity and urgency of detected incidents. The alerts can be sent through various communication channels, such as email, SMS, or dedicated monitoring consoles, ensuring that the responsible personnel can timely respond to security incidents.

Reporting

This sub-module generates comprehensive reports summarizing the monitoring activities, security incidents, and system performance. These reports provide valuable insights for stakeholders, management, and auditors. The reports can be customized, enabling the

presentation of specific metrics, trends, and compliance-related information. In this way, informed decision-making, risk assessment, and compliance monitoring are supported.

Visualization

This sub-module provides intuitive and interactive visual representations of the monitored system's state, security incidents, and relevant metrics. It presents complex data in a user-friendly manner, utilizing charts, graphs, and other graphical elements. Through the visualization sub-module, the security staff can gain a comprehensive understanding of the system's security posture, detect patterns, and identify potential areas of concern. Real-time visualization aids in situational awareness and decision-making.

Forensic Analysis

This sub-module focuses on investigating security incidents and conducting post-incident analysis. It utilizes advanced techniques and tools to trace the root causes of incidents, gather evidence, and support legal and forensic investigations if required. Additionally, forensic analysis aids in understanding the nature and impact of security incidents, enabling the implementation of preventive measures to mitigate future risks. Traceability of data is a crucial aspect of data protection within CIs. Ensuring the authenticity and integrity of data is critical for decision-making and accountability, especially in CI scenarios. Traceability refers to the ability to track the origin and changes made to data throughout its lifecycle, which is indispensable for investigating incidents, understanding the context of data, and establishing accountability.

1.3 Role of Data Provenance in CI Security Monitoring

In the current scientific and technological landscape, every system virtually relies on information, and CIs are no exception, as data is among the most critical assets to protect. Reliability of data involves guaranteeing its accuracy and trustworthiness. In CIs, relying on inaccurate data can lead to incorrect decisions, operational failures, or even safety hazards. In the event of a security breach or data compromise, having reliable Data Provenance can assist in the investigation and attribution of the incident. This is especially important when producing forensic evidence, where data and Data Provenance metadata must be certifiable. Data Provenance, also known as lineage or pedigree, is a research field meant to provide possible solutions to multiple concerns. Data Provenance records, in fact, provide information about the history and sources of data, ensuring its authenticity. It is clear that effective strategies for preventing and detecting attacks in CIs require careful data protection. Additionally, securing data can improve the effectiveness of monitor

components, which can perform a range of security functions such as firewalls, intrusion detection and prevention systems, and authentication. Existing monitoring approaches rely on data processing and verification of Data Provenance, and it should be possible to retrieve raw data for further analysis in specific scenarios. The application of Data Provenance in CIs extends beyond forensic analysis, playing a crucial role in enhancing the security of these infrastructures, especially in the context of emerging technologies such as AI. In AI-based applications, the integrity of the datasets is paramount. Through Data Provenance, it is possible to verify and validate the authenticity of data used to train AI models. This allow to track the lineage of datasets, therefore ensuring that the training data has not been tampered with, maintaining the reliability and trustworthiness of AI systems deployed in critical scenarios. Additionally, Data Provenance can validate commands in centralized systems, maintaining a record of their source and modifications, and preventing unauthorized access and manipulation. When integrated with Risk Assessment, Data Provenance enables early attack detection and mitigation. Establishing a secure and tamper-evident Data Provenance is therefore critical for safeguarding CIs against various threats and ensuring the resilience of the systems. However, making sure that Data Provenance records have not been altered is not trivial. In the following chapter, this concept is widely discussed and analysed, providing an overview of reliable Data Provenance in CIs.

Chapter 2

Background and Related Work

2.1 Data Provenance

Data Provenance is a research area that holds potential to support the reinforcement of CIs security and resilience. In fact, its application can ensure the integrity and reliability of data by recording and verifying a complete history of data, enabling auditing and digital forensics as well. Even the European Commission has proposed a Regulation on European data governance as part of its data strategy: this highlights the importance of tracking Data Provenance to ensure data reliability, integrity and authenticity, especially when it comes to data sharing and storage [3]. Data Provenance in CIs aims at a double objective: retrieving the original source of data, and tracing all the processes that have led to the current data. In this way, it is possible to ascertain quality, detect any sources of error or tampering, as well as simplify the correct attribution of copyright and compliance with regulations. With the advent of Industry 4.0, new threats have arisen in CIs: these systems, initially designed and developed without considering cybersecurity as the highest priority, are now targeted by new attacks, once exclusive to cybersystems. As previously discussed, poor data management causes significant vulnerabilities, which can result in serious consequences if exploited, especially in critical systems. In fact, these infrastructures are migrating toward Smart Infrastructures by deploying the IoT and investing in remote management and Big Data to improve the quality of service. The consequences of attacks on data range from the interruption of the service provided to, in the worst cases, disastrous consequences in environmental, economic and safety terms. This clearly shows that ensuring data reliability and trustworthiness is an essential task to prevent these kinds of consequences. Data Provenance, together with proper data management can provide a viable solution to these kinds of problems and consequences in CIs. The definition of provenance is complicated by the heterogeneity of the data involved. Sev-

eral international initiatives, such as the International Data Spaces Association (IDSA)¹, GAIA-X² or FIWARE³, aim to provide generic frameworks to share, manage and process data in the context of Industry 4.0 and Big Data, in order to enable data sharing through data spaces characterized by uniform rules. IDSA intends to guarantee data sovereignty by an open, vendor-independent architecture for a peer-to-peer network which provides control of data usage from all domains in a secure, trusted, equal partnership. The main goal is a global standard for International Data Spaces and interfaces. Gaia-X has the objective to address the challenges to the data environment within the European Union. The architecture of Gaia-X is based on the principle of decentralization, as a result of multiple individual platforms following a common standard. The end goal is a data infrastructure based on openness, transparency, and trust, by building a networked system that links Cloud Services Providers together in many critical scenarios, such as healthcare, energy, finance and so on. In 2021, IDSA and GAIA-X published a position paper to propose an integration of their individual approaches [8]: the merge would result in an architecture combining the data approach of International Data Spaces with the decentralized perspective offered by GAIA-X. The FIWARE Foundation promotes the FIWARE technological ecosystem, which aims at providing a modular, open and public software platform to enable multiple smart applications, including smart cities, smart agriculture, smart energy and more, which are strongly dependent on data. With a specific reference to the GAIA-X project, data provenance is defined as a retrospective recording of data flows and usages to support, for instance, data traceability or auditing [8]. Hence, it is clear that objectives that data provenance has to tackle in CIs are related to the management of the origin, development, ownership, location, and changes to data. This may also include personnel and processes used to interact with or make modifications to data.

In order to overview the role of Data Provenance in the recent security landscape, a literature review has been conducted, with a major focus on research works discussing tamper-resistant Data Provenance. The research has been performed among title, keyword and abstract of the studies, by exploring the following databases: Web of Science,⁴ Scopus⁵, and IEEE⁶. To select relevant Related Works, the following research criteria have been applied: (a) excluding any duplicate studies and extended versions of the same work, (b) excluding any work published before 2013 for an up-to-date analysis, (c) only considering the ones written in English, (d) excluding reviews, surveys, and works that were not research papers, and (e) removing the papers that were out of scope. The

¹<https://internationaldataspaces.org/>

²<https://www.data-infrastructure.eu/GAIAX/Navigation/EN/Home/home.html>

³<https://www.fiware.org/>

⁴<https://www.webofscience.com/wos/woscc/basic-search>

⁵<https://www.scopus.com/search/form.uri?display=basic>

⁶<https://ieeexplore.ieee.org/search/advanced>

following sections discuss the findings, providing background and motivation behind the work described in Chapter 3.

2.1.1 Blockchain-Based Data Provenance

Among the research work explored, a majority focuses on Blockchain to enable transparent and tamper-proof Data Provenance. A blockchain is a distributed, decentralized, and immutable ledger. Distributed means that each part of the network is located in different physical locations. The processing is spread across multiple users, called nodes. Decentralized means that a decision is made across various nodes. Each node decides its behaviour, which will eventually affect the network's behaviour. In this way, there's no single node that can access the system's information completely.

Blockchain technology can be defined as a subset of Distributed Ledger Technology (DLT), based on consensus algorithms between peer nodes. There's no central control and verification unit. Immutable means that a transaction cannot be tampered once it is packed into the blockchain. A transaction is a data packet that memorizes parameters and it's the result of function calls. Once data is stored in a blockchain, it can't be deleted or manipulated. It is possible to invalidate it, but the original data won't be affected. A Data Provenance record technique consists of the storage of data and operations as blockchain transactions.

A blockchain can be imagined as a pile of blocks, consisting of a block header and a block body. Each block contains three pieces of information: the actual data (depending on the type of blockchain), the cryptographic hash of the current block obtained by hashing process, and the hash of the previous block. The hashing process is a one-way process that consists in taking the input data and encrypting it using a hashing algorithm, such as Secure Hash Algorithm (SHA), a family of cryptographic hash functions published by the USA National Institute of Standards and Technology (NIST). A hashing algorithm returns an output string of fixed length that identifies and represents the block uniquely, acting as a unique fingerprint for that block. The blocks are linked according to the previous hashes, making the blockchain virtually secure and inviolable: in fact, the hash depends on the input and, consequently, changing the data or tampering it will lead to a new hash code of the block, different from the previous one. Hashing, therefore, is very useful for detecting alteration. A blockchain is based on consent between nodes. In order to reach consent, specific algorithms are required. Several algorithms have been developed in the past few years. However, the most popular consensus algorithms are:

- **PoW (Proof of work):** it requires proof that work occurred, such as hardware processing. The members of the network must expend effort solving an arbitrary mathematical puzzle to deter malicious uses of computing power, such as spam or

DoS attacks.

- **PoS (Proof of Stake):** it requires an actual stake of the currency to determine the next block. Instead of utilizing energy to answer PoW puzzles, a PoS miner is limited to mining a percentage of transactions that is reflective of their ownership stake.

The main difference between the two algorithms lies in the power consumption, which is much inferior in PoS. Many blockchain platforms are migrating from PoW to PoS or planning to do so in the next few years to make this technology more sustainable in terms of costs and energy [9]. Another notable consensus algorithm is the Practical Byzantine Fault Tolerance (PBFT), where consensus can be reached even in case a small number of nodes demonstrate malicious behaviour, such as falsifying information. Blockchain can be private, public, or permissioned. In a public blockchain, anyone is allowed to join the peer network, while in a private one only selected and verified participants are allowed. The validation is performed by the network operator(s), or by a pre-defined set protocol. A permissioned blockchain is characterized by properties of both public and private blockchains. In [10], a framework for protecting Provenance data in IoT environments is proposed. The framework addresses the requirements of tamper prevention, high availability, and access control for Provenance data through a fully distributed, lightweight, and keyless signature infrastructure in conjunction with attribute-based encryption and blockchain. The framework allows for the enforcement of fine-grained access control policies while assuring and enforcing the integrity of the Provenance data. BlockCloud [11] is a blockchain-based Data Provenance architecture that incorporates CloudPoS, a novel PoS-based consensus protocol for securely recording the data operations occurring in a cloud environment. Within BlockCloud, Data Provenance records are collected and published to a Blockchain. The system builds a public time-stamped log of all user operations on cloud data and assigns a Blockchain receipt to each Provenance entry for future validation. In [12] bcBIM, a Building Information Modeling (BIM) model enhanced by Bitcoin blockchain for BIM data audit, Provenance, and accountability is proposed. The framework ensures traceability by timestamp for recording BIM modification history. The authors design a blockchain-based method for BIM data aggregation including data structure and basic computation for consensus. The analysed system parameters include security strength, block size, packaging period, and hashing time cost. The work [13] explores how blockchain technology can be used as a solution to increase the security of the Bulk Electric Systems (BES) supply chain through a cryptographically signed distributed ledger that provides increased Data Provenance, attribution, and auditability. The Provenance framework proposed in [14] is based on the OpenStack Cloud platform and presents

a generic ledger interface meant to interact with various blockchain solutions, giving the Cloud provider the freedom to select the blockchain of choice. The system has been tested on Ethereum, Trillian, and Tendermint. In [15], a trusted Data Provenance application is implemented using Multichain. In this approach, Data Provenance is recorded by treating data as relevant assets in a transactional network. The proposed proof-of-concept application is based on existing research [16] to collect and verify Provenance by embedding it on a private blockchain platform. The same research is the basis of another framework [17], characterized by three Data Provenance phases: data collection from a network, access verification through blockchain technology, and transaction download for auditing tasks. These phases correspond to the approach and data treatment processes. In the same fashion, the framework proposed in [18] enables Provenance creation and storage on Multichain: the Provenance records consist of transactions on the Multichain ledger.

The authors of [19] propose a blockchain-based secure trading framework, including features such as decentralization, immutability, and integrity to solve the trust crisis in a centralized Provenance-based system. To improve the Provenance security, the Access Control Language (ACL) rule is proposed. Evaluation tests demonstrate that the framework minimizes the execution time when the number of transactions increases in terms of storage representation of Data Provenance and security.

The framework proposed in [20] aims at securing Data Provenance in IoT systems by combining blockchain and access control policies. The platform is implemented with hybrid attribute-based encryption, and the results are evaluated based on computational cost, the throughput of encryption and decryption, and the strength of the key, calculated according to the avalanche effect.

2.1.2 Data Provenance through Smart-Contracts

Some blockchain networks rely on smart contracts to define signature constraints between nodes and reach consent: Ethereum, Hyperledger Fabric, and RahaSak are among these. Smart contracts existed way before blockchain technology was introduced: a smart contract is a computerized transaction protocol that implements the terms of the contract. In other words, a smart contract contains all the constraints and the logical sequence of actions that need to be performed in order to effectuate and validate a transaction. Smart contracts are sandboxed and isolated: they can't access file systems, networks or any process running on the same machine. Once a contract is deployed on a blockchain, it can't be modified or updated again. For this reason, a deep testing phase is recommended before releasing the final version of the contract. Smart contracts can be written in several code languages according to the blockchain platform of interest. Smart contracts are

deployed to all the nodes within the network and executed when certain criteria are met. Three steps are required to deploy a smart contract: build a transaction object, sign the transaction and broadcast the transaction to the network. The usage of smart contracts for building Data Provenance framework architectures is a relatively new concept, and it has been the subject of recent research. An instance is [21], which proposes the architectural design of an application of blockchain technology to medication anti-counterfeiting and traceability systems. The work presents an optimization of the conventional PBFT consensus mechanism in the blockchain to enhance system operation efficiency in the process of medicine traceability.

Many platforms rely on existing blockchain platforms, such as Ethereum, as in [22], [23], [24], [25], [26], [27], [28], [29], [30], [31], [32]. Among the others, [22] was one of the first works exploring the potential of a blockchain-assisted information distribution system for the IoT. The study identifies key security requirements of a framework of this kind, discussing how to use blockchain and smart contracts to satisfy them. The proposed architecture is based on Ethereum and it adopts a gateway-oriented approach, where all blockchain-related operations are offloaded to a gateway, which in return provides an appropriate Application Programming Interface (API) for the Things to invoke. The work [23] proposes a framework for managing IoT medical devices and files by creating a distributed chain of custody and health data privacy scheme. A private blockchain is used in combination with on-chain smart contracts to allow for a forensics-by-design management architecture with audit trails for integrity and Provenance guarantees as well as health data privacy. The private blockchain ecosystem is authenticated by a proof-of-medical-stake consensus mechanism that is tailored for medical applications. In [24], Data Provenance for Integrated Circuits (IC) supply chain traceability is enabled through the combination of blockchain and Physically Unclonable Function (PUF). The blockchain provides a unique identifier for an IC. Using smart contracts, the proposed approach automates hardware and software protocols, allowing supply chain participants to authenticate, track, trace, analyze, and provision chips throughout their entire life cycle.

The framework proposed in [25] exploits blockchain's inherent advantages while associated with the development of authentication systems to provide transparency, consistency, and tamper-proof Provenance records. The user authenticates their Ethereum wallet address to the smart contract, which provides an access token and the shipper's Ethereum address. The user then assembles a package including their IP address, Ethereum public key, token access, and duration, which is signed with their Ethereum private key and sent to the IoT gadget. Upon delivery, the gadget controls the contents and allows access if successful, otherwise, access is refused.

In [26], the architecture for a tamper-proof Data Provenance extended, but not limited, to the healthcare scenario is proposed. The framework aims at protecting sensitive data, such as medical records. Transport Layer Security (TLS) is featured to secure off-chain data prior to the creation and storage of the Provenance records. Within the healthcare domain, [27] proposes a framework for product traceability in the medical supply chain, ensuring Data Provenance through ad hoc smart contracts and providing a secure, immutable history of transactions to all stakeholders. The stakeholders interact with the smart contract through pre-authorized function calls and with the decentralized storage for accessing data files. They also interact with on-chain resources to obtain information such as logs, InterPlanetary file storage system (IPFS) hashes, and transactions. The work [29], based on [27], presents a blockchain-based solution for managing data related to COVID-19 vaccines' distribution and delivery. Smart contracts automate the traceability of COVID-19 vaccines while ensuring Data Provenance, transparency, security, and accountability. Similarly, [28] proposes a framework for that leverages smart contracts and decentralized off-chain storage to ensure efficient drug traceability and which monitors the consumption of these drugs by patients according to a doctor's prescription.

The study [30] portrays an end-to-end approach to enhance the security of the food supply chain by monitoring systems and securing their components. Blockchain and smart contracts are used in combination with Tiny Machine Learning (TinyML) to ensure the integrity of collected data, enabling transparent traceability. TinyML is an emerging technology that can operate in constrained hardware and provide intelligent results by running ML locally on edge.

In [32], a blockchain with IoT-enabled permissionless network structure is designed called "B-SMEs" is proposed, providing solutions to cross-chain platforms. The blockchain permissionless public network is deployed along with two different chain-of-communication channels, such as off-chain and on-chain, that tackle a number of transactions that occur in the chain. The architecture also includes NuCypher threshold re-encryption with smart contracts and consensus policies for transaction protection and automation. Additionally, the IPFS is used to store logs of individual transactions that occur in the B-SMEs chain.

Within the SIGNED framework [32], the key component for Provenance management is the Traceability Layer, which includes a Verifiable Data Registry (VDR). The VDR is a smart contract deployed on the blockchain, in charge of managing and sharing public credentials of the components, such as public keys and public addresses, to ensure security and privacy requirements.

Another popular choice is Hyperledger Fabric, used as enabling platform in [33], [34], [35], [36], and [37].

In [33], a secure Data Provenance framework for a cloud-centric IoT network is pro-

posed. The proposed architecture is built on top of Hyperledger Fabric with the traditional Cloud infrastructure. In this approach, the cryptographic hash of the device metadata is stored in the blockchain whereas actual data is stored in the Cloud, to increase scalability and adapt it to the IoT environment. Multiple smart contracts are stationed in the blockchain to guarantee the Provenance receipt of the data stored in the cloud.

An architecture enabling lineage traceability in IoT devices is proposed in [34]. This approach proposes a privacy-preserving data management platform integrated with management hub nodes and off-chain storage service, making use of blockchain and public-key cryptography for identity authentication, authorization, and Provenance tracking mechanisms. The proposed architecture, implemented in Hyperledger Fabric, is compatible with a generic blockchain platform, public or private. The framework eChain [35] can detect counterfeiting in the electronic supply chain by enabling tracking and traceability. The integrity of the Provenance records in eChain is ensured through the immutable distributed ledger of electronic devices across the supply chain entities.

BlockHeal [36] is a framework for telehealth that integrates all essential healthcare services under one platform and ensures a full-fledged trusted environment, featuring Provenance and validated within several use cases. In [37] a blockchain-based product identification and certification system called Universal Identifier of Things (UIT) that enables fast product authenticity verification using low-cost devices. Products are embedded with unique identifiers, which are digitalized through the generation of a digital certificate, stored on a blockchain.

The blockchain platform Rahasak has been employed in [38], [39], and [40]. The platform Siddhi [38], through blockchain, Self-Sovereign Identity (SSI) enabled Cyber threat information (CTI), can realize traceability, anonymization, and Data Provenance in a scalable fashion for threat intelligence. Smart contracts are used for implementing functions such as identity verification and incident reporting. CySCPro [39] is a supply chain Provenance framework assuring cyber transactions in energy delivery systems, auditing logs in a tamper-resistant manner, and integrated with off-chain storage. Similarly, Vind [40] is a platform for enterprise-level Energy Delivery Systems (EDSs) that realizes Data Provenance in a cyber supply chain ecosystem.

2.1.3 Other Technologies

Blockchain-based approaches constitute the standard technique for the achievement of tamper-resistant capabilities. However, some alternative noteworthy approaches have been proposed and employed in literature. Among the others, a framework featuring tamper-resistance has been proposed in [41]. The proposed framework aims at ensuring the integrity of Provenance records in Cloud environments through a secure Provenance

chain, introduced in the work [42]. Provenance chains can prevent tampering attacks by tracking writes and securing the associated Provenance. The frameworks proposed in [43] and [44] aim at achieving tamper-resistant through the Trusted Platform Module (TPM). The TPM is a tamper-resistant cryptographic module embedded in the motherboards of various commodity systems, and it is able to provide a hardware root of trust for storing cryptographic keys and measurements, representing the current state of the system.

The framework proposed in [43], based on the TPM, enables secure Data Provenance in Cloud environments. The framework ensures the integrity and confidentiality of Provenance logs through the features of TPM, while the availability is guaranteed by storing the Provenance information in dedicated servers. ProvUSB [44] is an architecture for fine-grained Provenance collection and tracking on smart USB devices, featuring TPM for tamper-resistance. The framework is able to collect Data Provenance information by recording reads and writes at the block layer and reliably identifying hosts editing those blocks through attestation over the USB channel with acceptable overhead.

Some frameworks enable tamper-evidence, therefore supporting the detection of tampering attacks. The framework WORAL [45], is a ready-to-deploy framework for generating and validating witness oriented asserted location Provenance records to enhance supply chain security. The WORAL framework allows user-centric, collusion-resistant, tamper-evident, privacy-protected, verifiable, and Provenance preserving location proofs for mobile devices.

In [46], starting from their previous research, the authors propose VisualProgger, a real-time security visualization application (web and mobile) visualizing Data Provenance changes in a tamper/evident fashion. The application has been used to evaluate a full-scale security visualization effectiveness framework developed by the same researchers.

The PDMS framework, proposed in [47], is a Provenance-based monitoring and forensic analysis framework that builds upon existing Provenance collection and tracking framework. Evaluation results show that PDMS is able of keeping a low Provenance storage overhead, and it can be used to detect tampering. Specifically, PDMS has been tested to detect file tampering and it has been shown how further analysis of the whole Provenance graph can accurately ascertain the attack source as well. In [48], a secure Provenance tracking framework for IoT is proposed. The framework uses the partial encryption techniques of CP-ABE (Ciphertext-Policy Attribute-based Encryption) by offloading an IoT node. The IoT node only calculates the partial digital signature, while the heavy-loaded computation is performed by the edge node. Through hash-based searching, the Provenance tracking time decreases. The research shown in [49] uses a set of pre-existing tamper-free frameworks for Data Provenance to test a novel algorithm to mitigate poisoning attacks through Data Provenance. The majority of the works analyzed throughout

the SLR process feature the usage of blockchain technology to collect and store Data Provenance information in a tamper-resistant fashion. In Chapter 3, the results of this discussion are employed as a foundation for the design, implementation, and validation of the ATRS, a novel framework for Data Provenance tailored for the CI domain.

2.2 Attack Detection

In ensuring resilience and continuity of CIs, it is mandatory to take into consideration effective attack detection. In fact, the reliance of such systems on digital technologies exposes them to various cyber threats, ranging from targeted attacks to malicious infiltrations. Prompt detection can make a difference in terms of the impact these threats may have, not only on the individual infrastructure, but on a wider landscape, due to their interconnected nature. In the context of an inclusive security monitoring framework, attack detection serves as the frontline defense mechanism through continuous monitoring of network activities, anomaly analysis, and security incidents identification. The integration of advanced technologies and methodologies for attack detection enhances the overall cybersecurity posture, and key elements of security monitoring include SIEM, as previously explained, and Intrusion Detection Systems (IDS). Within this Thesis, the proposed solution for attack detection in CIs is presented in Chapter 4. While SIEM systems provide a wider context for security monitoring, IDS operate on the front lines, acting as specialized probes dedicated to specific activities. IDS can commonly operate following two distinct approaches: signature-based and anomaly-based [50] [51]. Signature-based IDS search for predefined patterns or signatures of known threats. Comparable to common antivirus programs, these systems prove highly effective in identifying well-established attack vectors. On the other hand, they may face challenges with unknown or sophisticated attacks. Anomaly-based IDS, instead, establish a baseline of normal behavior through continuous monitoring during a training phase. The system raises alerts when deviations from this baseline are detected. While effective in identifying previously unknown threats, this approach requires accurate tuning to avoid generating high false positives.

2.3 Machine Learning in Attack Detection

Despite SIEM and IDS remain reliable tools in the protection in CIs, cyberattackers keep to continuously evolve their tactics to exploit vulnerabilities in digital systems [52], finding new schemes to avoid classic prevention and detection techniques [53] [54] [55]. To address the limitation of classic SIEM systems against novel and complex attacks, several approaches have been proposed in the literature. For instance, a next-gen SIEM

framework leveraging ML is proposed in [56]. The combination of Software-Defined Networking (SDN) and AI is exploited in [57] to create a robust SIEM system, meant to protect Industrial Internet of Things applications.

Other research investigates the application of Deep Reinforcement Learning (DRL) in optimizing post-alert incident responses in SIEM systems [58]. The ML-IDS proposed in [59] aims at detecting IoT network attacks, with a focus on privacy challenges. In the same application domain, [60] proposes an IDS enhanced with a hybrid Convolutional Neural Network (CNN) model. The study conducted in [61] proposes a packet-based ML model with deferred decision and a single packet integration classifier for network intrusion detection. The solution proposed in [62] consists of a two-stage hybrid methodology for intrusion detection using ML. A classification-based NIDS using big data analytics tools and deep learning approaches is proposed in [63]. Specifically, a Hybrid Deep Learning (HDL) network consisting of CNN and Long short-term memory (LSTM) is used for better results. The potential of ML-NIDS is also highlighted in [64]. In this work, a robust ML-NIDS is proposed, addressing the limitation of classic hybrid approaches, which are vulnerable to attacks not present in the training set. In the following, more related works are showcased, with a focus on Association Rule Mining (ARM) and Explainable Artificial Intelligence (xAI). As shown in Chapter 5, these findings have been the starting point to enhance the CADF with ML techniques, with the aim to improve attack detection.

2.3.1 Association Rule Mining

Association Rule Mining (ARM) is a data mining technique that allows to uncover hidden relationships within dataset's features. As shown in the literature, ARM offers a valuable toolkit for enhancing cyber incident detection, optimizing alert management, and reducing false positives. In [65], the authors investigate the integration of associative rules into SIEM systems to improve the detection of cyber incidents. The proposed approach incorporates fuzzy sets theory and data mining techniques to construct associative rules based on the analysis of cyber incidents. In [66], sequential rule mining is employed in the analysis of intrusion detection alerts. The main goal is to reduce the volume of alerts received by security professionals. The work presented in [67] addresses the common issue of false positive alerts generated by intrusion detection systems. The study proposes a novel network security IDS framework that leverages Modified Frequent Pattern (MFP-Tree) with the K-means algorithm in detecting several kinds of attacks. The authors of [68] introduce a method for mining association rules from multi-source logs to identify various intrusion behaviours in cloud computing platforms.

2.3.2 Explainable Artificial Intelligence

Within AI, xAI has been gaining popularity in the cybersecurity [69] [70] [71] [72]. The aim of these methods is to provide human-understandable explanations of ML models, to improve model transparency, robustness, and user trust. While multiple xAI methods have been proposed in the literature, the most common include feature importance, rule-based explanations, and counterfactual explanation. These methods can help cybersecurity professionals understand how ML models are making decisions, as well as identifying potential biases in the models and supporting debugging problems that might arise. Additionally, xAI can be employed to identify the most important features for the model's predictions. In the realm of IDS, [72] introduces an advanced IDS utilizing ML ensemble methods like Decision Trees (DT), Random Forest (RF), and Support Vector Machines (SVM), achieving promising results. It incorporates xAI with the LIME algorithm to enhance model transparency. In [73], the critical role of trust management in IDS is explored, emphasizing the need for transparency in ML models utilized in the cybersecurity domain. It discusses the challenges of interpreting "black-box" AI models and the importance of xAI in enhancing trust by enabling human experts to comprehend the model's decision-making process. The paper [74] introduces an IDS employing ML techniques like DT, RF, and xAI on real-world SDN data. The evaluation covers various intrusion scenarios, achieving high accuracy. In [75], an approach for detecting DDoS attacks using xAI is proposed. The method focuses on identifying attack behaviours in network traffic flows without analyzing packet payloads. The work carried out in [76] aims at contributing to rigorous xAI-equipped IDS for DDoS attacks.

Chapter 3

The Advanced Tamper-Resistant Storage

In this chapter, the proposed solution for Data Provenance in CIs is presented. The ATRS is designed to collect data from various sources and store Data Provenance records on a blockchain-based unit. This approach provides transparency and traceability, along with tamper-resistant capabilities. The chapter details the key modules of the framework, and introduces a system evaluation to illustrate the implementation of the ATRS and assess its performance and cost-effectiveness.

3.1 Proposed Architecture

After the detailed analysis of the state of the art of Data Provenance in CIs, conducted through the analysis and classification of the related papers, this section describes the architecture of the proposed solution for Data Provenance recording within the context of CIs. This solution adopts a general provenance Data Model able to cope with the possible sets of heterogeneous data, describing a framework for the effective management of huge amounts of data, offering also tamper-resistant capability.

The ATRS is able to collect data from various sources and generate Data Provenance records, which are stored on a blockchain-based storage unit. Through blockchain technology, it is possible to cryptographically sign the who, what, when, and where for critical cyber-assets, allowing for transparency and traceability. The ATRS is in charge of secure storage and Data Provenance verification: it enables the creation, update, and retrieval of provenance records. Once a record is created and stored within the ATRS, it cannot be deleted: however, it is possible to invalidate it, making it impossible to use it as input for further processing. This does not go against the right to the erasure of the General Data Protection Regulation (GDPR) [77], since the records are not meant to contain any

personal information. The data flow of the framework can be schematized as shown in Figure 3.1.

The key modules of the framework include:

- **Processing Unit:** This component receives the data from various sources (asynchronous and synchronous), parses it, and creates, updates, and deletes (invalidates) Data Provenance records. Each provenance record is composed of a unique identifier (TokenId) and the actual data (context).
- **Cache:** This module acts as a buffer, and enables retrieval of raw data in case of anomalies.
- **Blockchain:** The blockchain acting as a tamper-resistant storage.
- **Human-Machine Interface:** The graphical user interface to interact with the ATRS.

The Processing Unit is the core of the framework and it is in charge of retrieving and parsing data from the various processes. This module utilizes the functions defined in the smart contracts underneath for the creation of provenance records through a Web3 interface. Web3 is a collection of libraries that allow interaction with an Ethereum client through HTTP (Hypertext Transfer Protocol), IPC (Interprocess Communication), or WebSocket. To ensure the protection of off-chain data, the communication between the components is established through a secure communication link based on the TLS protocol. The HMI is a graphical interface that allows the user to retrieve the provenance records.

The Blockchain component is based on state-of-the-art product [78]. It is a framework able to create and store Data Provenance records in a three-layers architecture, composed of Solidity smart contracts deployed on Ethereum. Within the present research, the contracts have been modified to optimize costs and performance per transaction. In fact, the Solidity compiler tries to bundle the next variables together only if they are of the same type, otherwise, they are considered and processed as individuals, with a consequent increase in the computational cost. Thus, the variables are listed in the smart contract in a specific order, to have them bundled as one rather than processed individually.

The proposed implementation uses the Ethereum token standard ERC721¹, which defines a common interface for non-fungible assets. This standard allows the transfer of ownership, which is necessary to ensure that records entering the systems originate from a specific client of the system, who's in charge of creating provenance records for that data point. This is meant to prevent unauthorized users from creating provenance records.

¹<https://ethereum.org/en/developers/docs/standards/tokens/erc-721/>

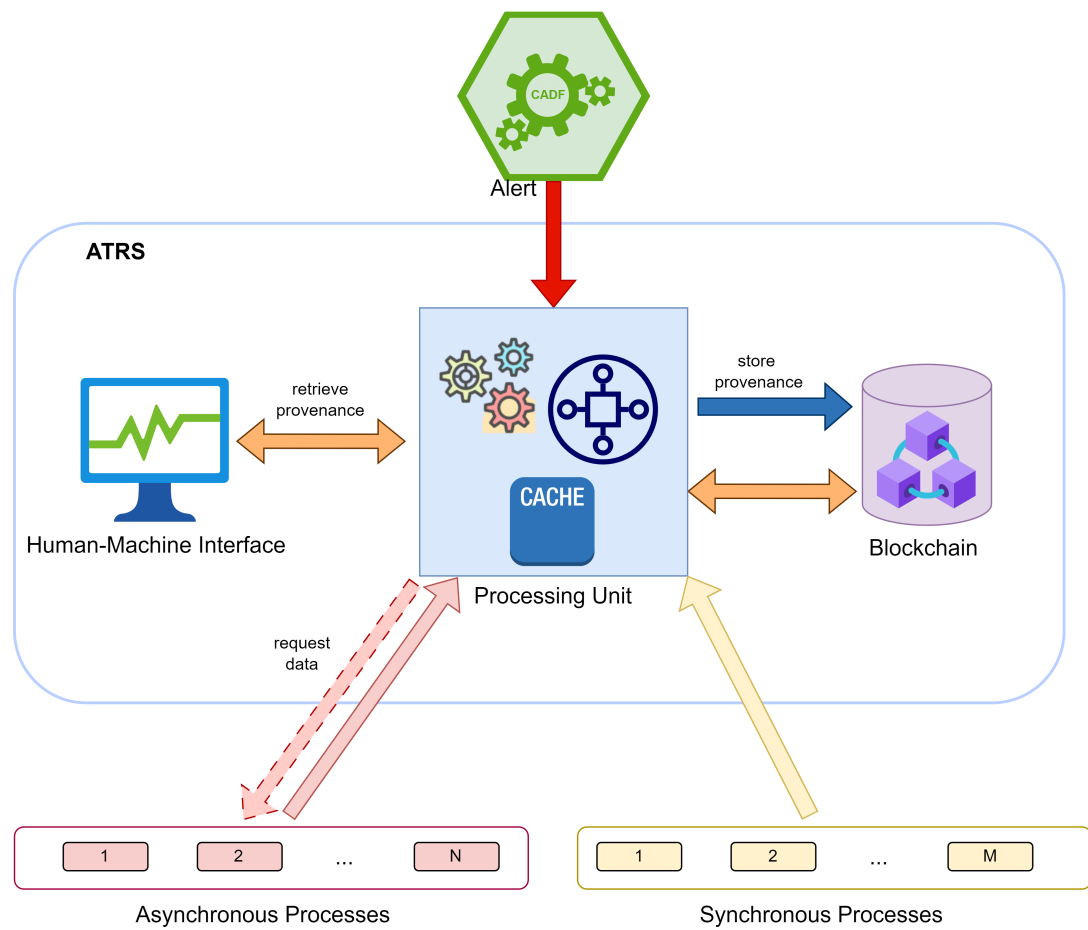


Figure 3.1: High-level architecture and data flow of the ATRS. The direction of the arrows indicate which component is receiving data and/or commands.

The `tokenId` is used as input for the creation of a new provenance record along with the data sent from the processes, and the CADF alert. Each time a new provenance record is created, two new blocks are added to the chain. In particular, the first block contains the transaction relative to the generation of the new `tokenId` required to track the data point received. The second block contains the transaction relative to the actual provenance record. In this block, the “context” field displays the input data. Additionally, all the necessary provenance information is displayed, including the `tokenId`, and the `provId`, a unique identifier of the specific provenance record. The creation of a provenance record is triggered by an alert from the CADF. The CADF system can detect cyber-attacks on monitored systems and applications through a set of probes. The probes act as sources for the correlation logic of the CADF, enabling the creation of alerts in case of anomalies. Each alert is identified by a unique ID as well.

3.2 System Evaluation

This section focuses an example use-case of interest, providing details regarding the implementation of the simulation performed, along with performance evaluation. This use case scenario and the one presented in Section 4.2.2 have been implemented in the Energy domain. However, it is worth to mention that both the ATRS and the CADF can be used for a wider scope for virtually any CI.

3.2.1 Use Case

Within Smart Grids, Data collection and monitoring are obtained through two keys enabling technologies, integrated together for the exchange of information through the rapid communication medium:

- **Phasor measurement units (PMUs)**: also known as synchrophasors. These devices can measure the electrical waves on a power grid using GPS signals as a common time source for synchronization. These units are able to measure real-time power system quantities, simultaneously and in a distributed area, while allowing the collection of time-stamped measurements.
- **Phasor data concentrators (PDCs)**: these are nodes where phasor data from several PMUs are correlated and output as a single stream to other applications.

The interaction between PMUs and PDCs follows a client/server protocol: PMUs operate in a server mode, allowing clients such as PDC to connect to it. The Data Collector, in this scenario, is composed of a set of PMUs. The PMUs retrieve tension and current information (magnitude and phase angle) within the simulated smart grid, and forward

Table 3.1: Data Message frame organization according to the IEEE C37.118 standard

Data Message Field	Size (bytes)	Description
SYNC	2	Sync byte.
FRAMESIZE	2	Size of the frame in bytes.
IDCODE	2	Unique stream identifier.
SOC	4	Second of Century timestamp.
FRACSEC	4	Fraction of Second count.
STAT	2	Bit-mapped flag.
PHASORS	8/16	Phasor estimates.
FREQ	2/4	Frequency.
DFREQ	2/4	Rate Of Change Of Frequency.
ANALOG	8/16	Analog data.
DIGITAL	4	Digital data.
CHK	-	Cyclic Redundancy Check (CRC-CCITT).

it to the Processing Unit through the TLS protocol: the Processing Unit is acting as a PDC, by receiving and processing data collected by the synchrophasors. The command flow between PMUs and Processing Unit follows the IEEE C37.118 standard², which is the standard protocol for communication between PMUs and PDCs. The standard defines four types of messages: data, configuration, and header (transmitted from PMU) and command (received by the PMU). Specifically, data messages are the measurements collected by the PMU. Configuration messages, machine-readable, describe the metadata sent by the PMU. Header messages, human-readable, describe all information sent from the PMU but described by the user. Finally, commands are machine-readable codes employed for control or configuration. Each PMU could transmit multiple data streams that must be uniquely identified. For the sake of brevity, Table 3.1 lists and defines frame organization of data messages according to the standard, in a concise way.

As shown in Figure 3.2, once the Processing Unit connects to the PMU server, it must retrieve the PMU configuration by sending the Configuration request frame.

As a response, the PMU sends the Configuration frame, containing information that the Processing Unit will use to decode the data. At the reception of the Configuration frame, the Processing Unit sends the request to start the data transmission, and the PMU starts transmitting data at a fixed rate. The Processing Units accepts and decodes the data from the PMU. When the Processing Units sends the request to stop the transmission, the PMU stops transmitting data. The ATRS acts as a passive tool: the Processing Unit is constantly receiving data from Synchronous processes (in this use case, PMUs)

²<https://standards.ieee.org/ieee/C37.118.1/4902/>

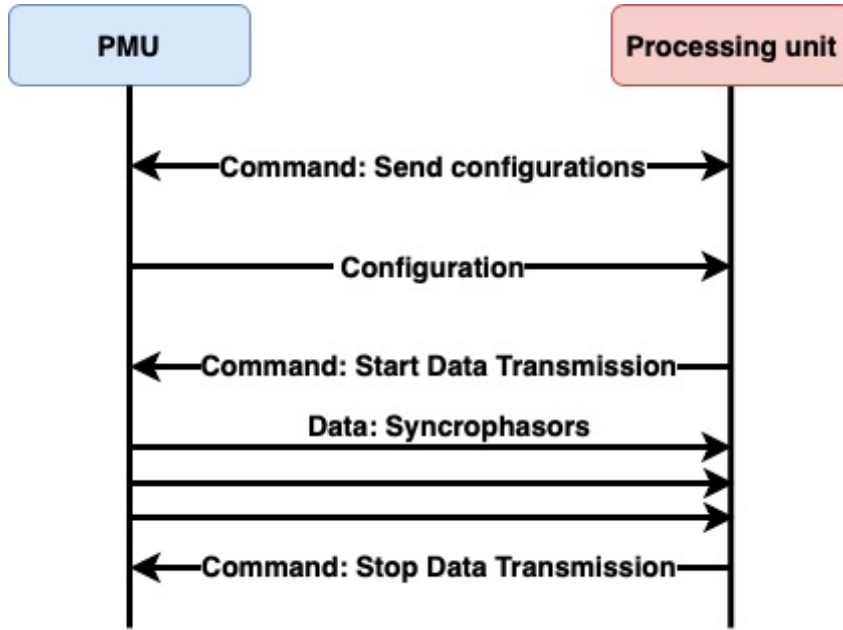


Figure 3.2: PMU and Processing Unit command flow according to the IEEE C37.118 standard

and storing it in Cache. Whenever an alert is raised, the Processing Unit requests to the asynchronous processes all the data produced within the monitoring time window of the CADF (i.e. 10 minutes before the alert). Data cached in the same time window is also retrieved, along with the alert ID. All this information is stored on-chain, bundled in a provenance record. This feature allows the ATRS to only store anomalous data that can constitute symptoms of attacks. In this way, the ATRS enables support in case of incidents through a reliable forensic analysis, making it suitable for adaptation to a wider range of possible use cases and applications.

3.2.2 Performance Evaluation

To evaluate the performance of the ATRS, two parameters have been considered: processing time, and cost. The results of the time processing evaluation is shown in Figure 3.3. The input data constitutes the context field of the provenance records. The processing time has been evaluated by feeding simulated data, ranging from 1B to 1KB. The context field is approximately 104B for sample PMU inputs, leading to an average processing time of approximately 1s for the creation and storage of a provenance record. The proposed framework aims at storing data in cache by default, and storing on the Blockchain only measurements that allowed the detection of anomalies. The data rate for PMU and PDC communication typically ranges from 1 sample per second to 120 samples per second. The performance is considered acceptable for the proposed application. Similarly, the

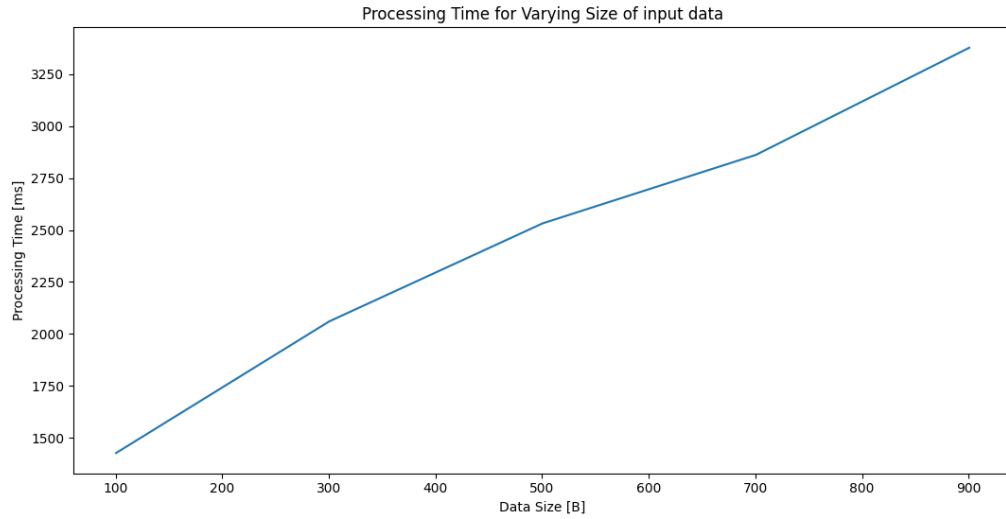


Figure 3.3: Performance evaluation of the ATRS. The test was conducted by feeding input data of increasing size to the framework

cost analysis performed is shown in Figure 3.4

In the proposed approach, based on the Ethereum blockchain for storage, the transactions for the TokedId request and the creation of a new provenance record have a cost in Ether, the Ethereum crypto-currency, corresponding to a cost in traditional currency. Since any Ethereum transaction requires computational resources to be processed within the blockchain, a commission fee (gasFee) is required to successfully perform the transaction. The gasFee is calculated according to Eq. (3.1):

$$gasFee = \frac{gasPrice[Gwei] * gasUsed}{10^9} [ETH] \quad (3.1)$$

In Ethereum, “gas” is a unit that identifies the amount of computational power necessary to execute a specific transaction, measured in wei, the smallest denomination of Ether. The gasFee depends on the cost per gas unit that a user is willing to pay for the transaction, and the units of gas required for said transaction (gasUsed). The cost analysis of our experimental approach is reported in table 3.2. The gas units required for the various operations have been evaluated setting a gasPrice of 20 Giga-wei. Since the ATRS is meant to act as a passive tool, and only store secure relevant data when triggered by a CADF alert, the cost analysis is considered satisfying.

Table 3.2: Cost Analysis for the creation of a provenance record.^a

Transaction	Gas Unit	GasFee	Cost
TokenID request	149'000	0.003 ETH	€ 4,04 / \$ 3,93
Provenance record	250'000	0.005 ETH	€ 6,73 / \$ 6,55
TOTAL	399'000	0.008 ETH	€ 10,78 / \$ 10,51

^aCost is relative to the currency exchange at the time of the writing.

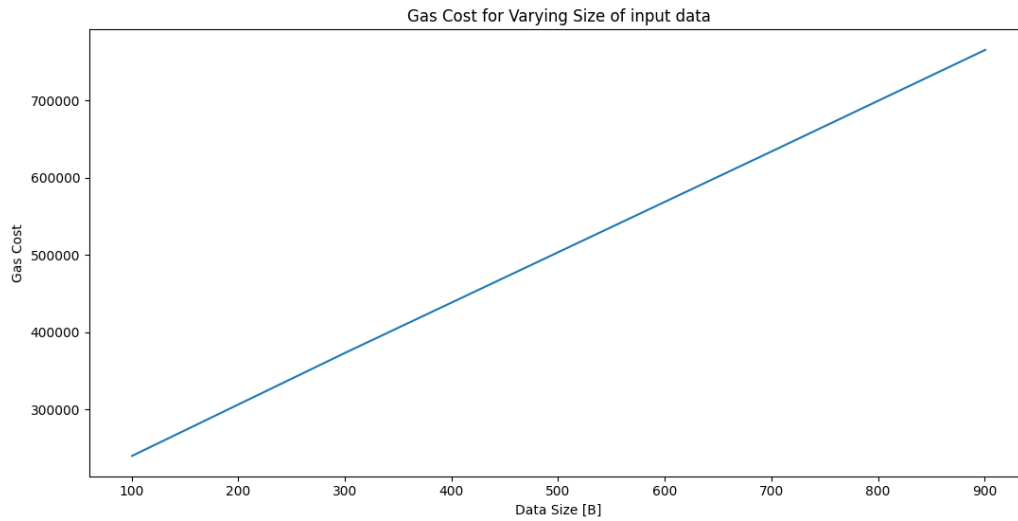


Figure 3.4: Cost evaluation of the ATRS. The test was conducted by feeding input data of increasing size to the framework

Chapter 4

The Cyber-Attack Detection Framework

This chapter introduces the CADF, the proposed solution for attack detection in CIs. The next sections outline the architecture and components of CADF focusing on its key features. A use case scenario in the Energy domain is also presented, demonstrating how CADF can effectively detect and respond to a combined brute force and device alteration attack. The CADF's ability to identify and respond to threats targeting confidentiality and integrity is showcased, along with its integration with the ATRS.

4.1 Proposed Architecture

The CADF is a key component of the proposed security monitoring solution, concerned with improving the security of Critical Infrastructures alongside the pre-existing security systems.

Figure 4.1 shows how the CADF places itself within the conceptual architecture described in Section 1.2, highlighting the subset of functionalities that the CADF is able to provide. In order to achieve specific functionalities, the CADF is equipped with ad hoc modules, as detailed in the following subsections and shown in Figure 4.2. The dedicated modules are in charge of real-time log collection, parsing and consolidating events, efficient event stream management, correlation logic, intuitive rule creation, long-term data storage, and visualization. Despite their widespread adoption, common SIEM products can face limitations that affect their effectiveness in securing CIs. Among these, the sheer volume of data collected can quickly overwhelm SIEM systems, leading to performance degradation and false-positive alerts. This is particularly concerning for CIs, where real-time threat detection is crucial for preventing disruptions or outages. Another limitation lies in the need of correlating data from diverse sources within a complex infrastructures, as most

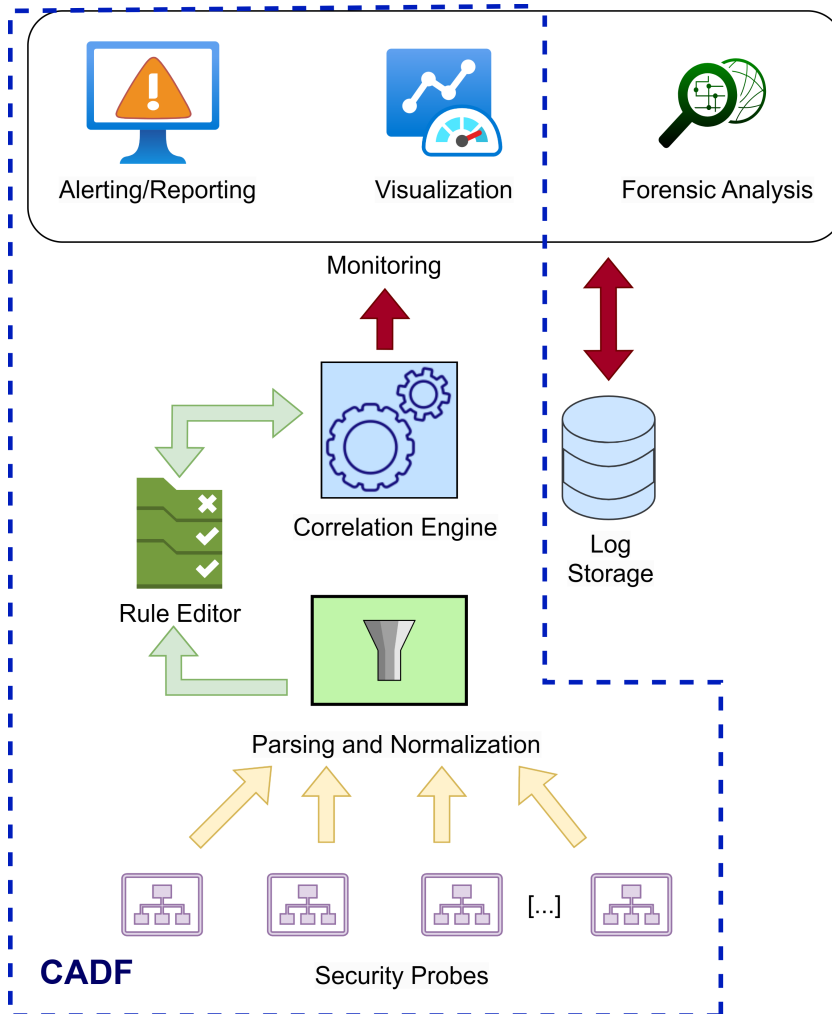


Figure 4.1: Functionalities of the CADF in accordance to the proposed architecture of Security Monitoring framework for CIs.

SIEM tools can struggle to effectively integrate data in such a complex scenario. Furthermore, SIEM products often rely on simple rules and predefined threat signatures to detect anomalies. With respect to traditional solutions, the CADF implements a scalable architecture, fit for a holistic security framework tailored for CIs. It implements real-time monitoring designed for wide and complex infrastructures, and it addresses the lack of extensive sets of built-in rules against common CIs threats that traditional SIEM might face. The CADF has also been tested against a variety of realistic scenarios within actual CIs, as detailed in Section 4.2. Additionally, the tool has been augmented with ML techniques (Chapter 5: these advanced methods can analyze large datasets and identify patterns that deviate from normal behavior, potentially uncovering hidden threats that may not be detected by traditional SIEM systems).

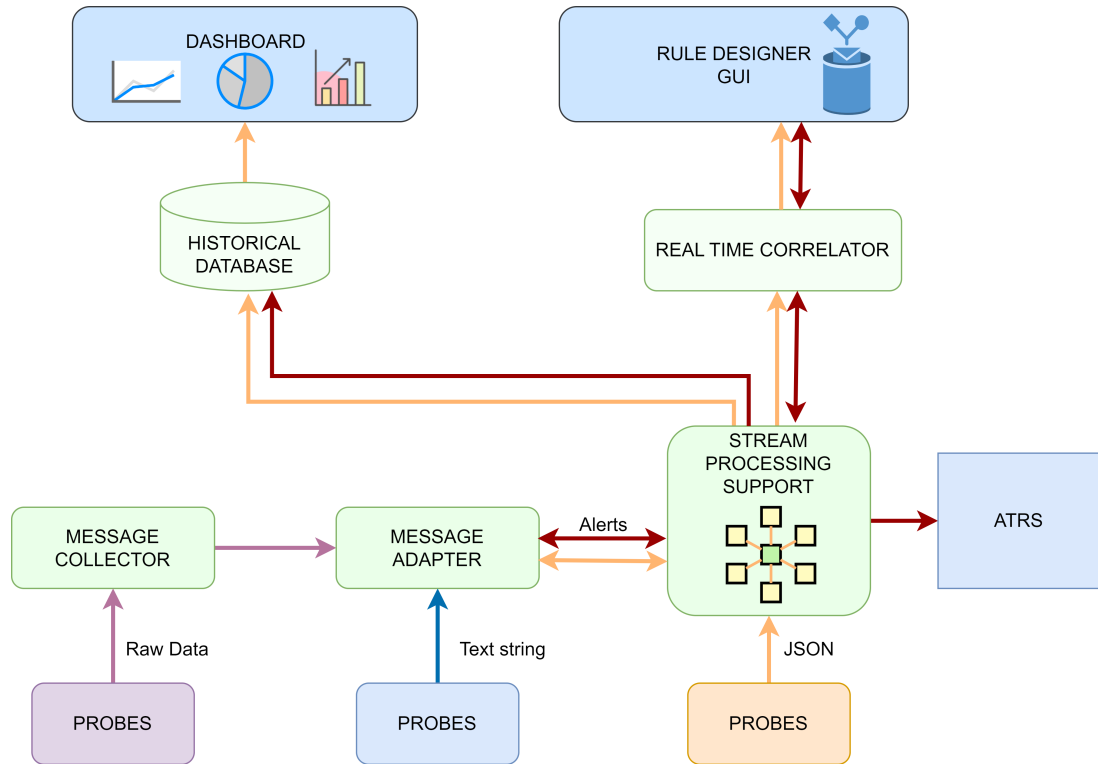


Figure 4.2: High-level architecture and data flow of the CADF

The detailed architecture of the CADF is depicted in Figure 4.2. As shown in the figure, the architecture consists of various components that work together to provide attack detection capabilities. The following illustrates each component in more detail to provide a deeper understanding of their roles and functionalities.

4.1.1 Message Collector

At the heart of the architecture lies the Message Collector, a lightweight shipper specifically designed for real-time log collection. Its primary function is to gather logs from end-node applications or probes. By monitoring log files or predefined locations, the Message Collector swiftly captures logs and forwards them to the Message Adapter for further processing. This real-time log collection ensures that no critical security events go unnoticed.

4.1.2 Message Adapter

The Message Adapter acts as a vital intermediary between the Message Collector and other components in the architecture. Its responsibilities include receiving and consolidating events from the Message Collector, parsing the collected data, and processing it

for further analysis. Through the use of input plugins, the Message Adapter can apply personalized data transformations and enhancements to the collected logs. These transformations and enhancements can be customized using filter plugins, ensuring that the messages are aligned with the specific information requirements of the monitoring phase. Within the CADF, all the alerts are converted to Intrusion Detection Message Exchange Format v2 (IDMEFv2) and forwarded to the modules responsible for the mitigation stage. The purpose of IDMEF is to define data formats and exchange procedures for sharing information of interest to intrusion detection and response systems and to the management systems that may need to interact with them. The details of the IDMEF format are described in the RFC 4765¹. Additionally, we use IDMEFv2 to include geolocalization and information related to the source, target, and assets involved. The CADF utilizes a highly scalable framework architecture that ensures effective and efficient protection. By converting relevant alerts into IDMEFv2, the Message Adapter enriches the log data with additional contextual information such as geolocation, source, target, and involved assets.

4.1.3 Stream Processing Support

The Stream Processing Support component plays a crucial role in managing the events received from the Message Collector. It possesses powerful capabilities to handle the processing and storage of event streams. The Stream Processing Support can read and write events efficiently, ensuring high-performance data ingestion and retrieval. It also acts as a central hub for importing and exporting data to and from other components, such as the Historical Database, Real-Time Correlator, and Dashboards. To organize the data, the Stream Processing Support creates separate topics for each data source. Whenever a message is stored in a topic, it is marked with a time-stamp, allowing for easy tracking and analysis of events over time.

4.1.4 Real-Time Correlator

The Real-Time Correlator module enhances the architecture's monitoring capabilities by enabling correlation logic. It works in conjunction with the Rule Designer component to identify relationships and patterns among the incoming events. Leveraging the data streams from the Stream Processing Support, the Real-Time Correlator can apply correlation rules to the events in real-time. These correlation rules are designed using the Rule Designer, allowing security analysts to create customized logic for detecting complex security incidents. The Real-Time Correlator provides a flexible and intuitive interface to view, start, and stop the correlation rules, empowering analysts to effectively manage

¹<https://www.rfc-editor.org/rfc/rfc4765.html>

the monitoring system's behavior.

4.1.5 Rule Designer

The Rule Designer component simplifies the process of creating correlation rules by offering a user-friendly graphical interface. Security analysts can easily define the logic for identifying security incidents by selecting the appropriate data sources from Stream Processing Support. The Rule Designer allows analysts to specify conditions, thresholds, and relationships between events, enabling the creation of accurate and tailored correlation rules. This intuitive design significantly reduces the time and effort required to develop and modify correlation rules, empowering analysts to adapt the monitoring system to evolving security threats effectively.

4.1.6 Historical Database

To support long-term data storage and analysis, the architecture incorporates a Historical Database component. The Historical Database is specifically designed to handle the persistence of time-stamped or time-series data generated by the security monitoring system. It provides a robust and scalable storage solution for storing large volumes of security-related data over extended periods. Security analysts can leverage the Historical Database to run complex queries and perform aggregations on the stored data. These advanced querying capabilities enable analysts to gain valuable insights and enhance situational awareness. By aggregating and displaying events that have occurred over time, the Historical Database enables retrospective analysis and aids in the identification of historical security trends.

4.1.7 Dashboard

The Dashboard component offers a comprehensive and intuitive user interface for visualizing and exploring the indexed data stored in the Historical Database. It serves as a centralized platform for security analysts to access and analyze the collected information in real-time. Through the Dashboard, analysts can perform searches, apply filters, and generate visual representations of security events and incidents. This enables quick identification of anomalies, threats, and trends, empowering analysts to respond promptly to emerging security risks. The Dashboard provides a user-friendly browsing experience, allowing analysts to navigate through the historical data easily and gain valuable insights into the security posture of the critical infrastructure.

4.2 Use Case and Validation

Here is the revised text with corrections:

Throughout its development, the CADF has been tested and validated for multiple use cases, including simulated scenarios in actual CIs within the Space Sector and the Energy domain. In the latter, the CADF has been integrated with the ATRS, as shown in Section 3.2.

The experiments involved the design and assessment of probes and rules tailored to address a wide spectrum of threats, as detailed in the following.

4.2.1 The CADF in the Space Sector

This subsection overviews a set of scenarios where the CADF has been evaluated and tested in the Space Sector. The tool addressed unique challenges like Radio Frequency (RF) Interference, including Jamming and Spoofing attacks, employing specialized probes and rules to detect and mitigate these threats [79].

In the simulated scenario, the attack begins when a malicious individual located in close proximity to the Satellite Ground Segment (GS) premises creates interference using a jamming device. This interference causes distortion of the satellite images received by the receiving equipment, along with alteration of the reception parameters. Monitoring parameters' data of satellite signal reception, information received from the satellite operator related to weather conditions, and historical data regarding possible interference in the past in specific directions are collected and correlated by the CADF. When the received monitoring parameters of satellite signal reception deviate from the normal ones, RF reception anomalies are detected. The reception values and the conditions in the GS area are correlated according to the correlation rules, eventually raising an alert. The correlation leads to the evaluation of whether there is a jamming attempt or if the detected anomalies are within normal conditions, such as malfunctions. Finally, a comparison of the current images with a sequence of images received before the alarm may be used for confirmation of spoofing attacks.

Within the same domain, probes dedicated to the detection and data collection of potential threats have been specifically crafted to monitor instances of DoS and DDoS attacks, distinguishing between network and application-level anomalies. In these scenarios, the dedicated probes collect real-time logs from the monitored service/application, including traffic information and system metrics. In the tests, the network-level DDoS is a volumetric attack, where the target website is overwhelmed with a massive volume of traffic. The CADF can correlate the high volume of network requests with bandwidth and CPU increase. As a result of the correlation, an alert is raised, and the attackers' addresses

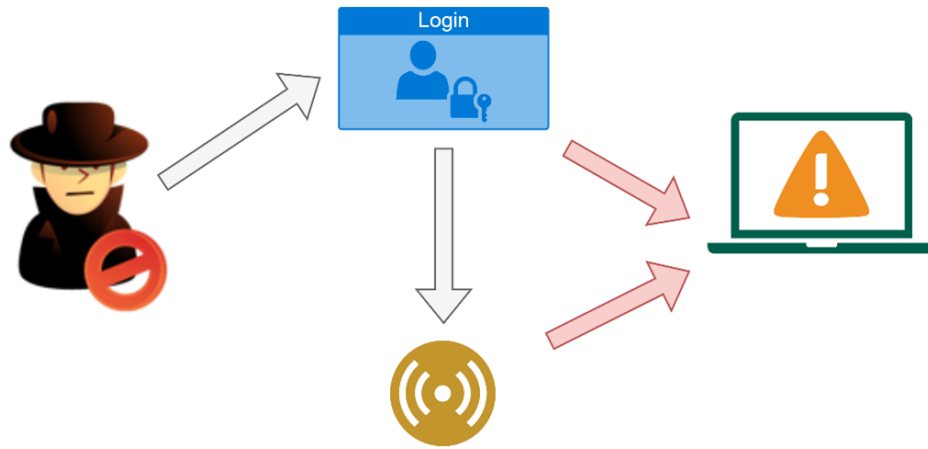


Figure 4.3: Use case example for the CADF. A combined brute force and device alteration attack is detected.

are detected and blacklisted. Instead, in the application-level DDoS, the attackers manage to make the service unavailable using a limited number of computationally complex queries, followed by anomalous memory usage and CPU increase. The events, correlated in real-time by the CADF, are recognized as anomalies, and an alert is raised.

Rules enabling the identification of threats such as Ransomware, with a focus on early detection, have been designed as well. The tested scenario can be summarized as follows: a malicious insider installs ransomware that uses an encoding mechanism to encrypt and modify critical files saved on the targeted infrastructure. Through a dedicated probe, the CADF detects and notifies changes in the monitored files, correlating such events with CPU, disk usage, and network anomalies. As a result, an alert is generated.

Privilege Escalation scenarios were also considered by employing rule sets that monitored user activities and system interactions for potential unauthorized escalations, and unauthorized access attempts were detected through rules that analyzed access patterns and anomalies. In the considered scenario, intruders are able to perform a small-scale cyber attack and install a new laptop in the network of the Satellite GS, with the aim of gaining remote access to critical information. The unknown host is detected, and an alert is raised.

4.2.2 The CADF in the Energy Domain

The present subsection provides a detailed description of a use case scenario for a combined brute force and device alteration attack, where the CADF has been tested together with the ATRS in the Energy domain. The main focus is therefore on attacks targeting Confidentiality and Integrity. The use case is schematized as shown in Figure 4.3

First, a malicious user starts a brute force attack to steal legitimate credential. The

```

1  {
2  "version": "1.0",
3    "alert": {
4      "Description": "Anomalous device alteration detected",
5      "Cause": "Malicious",
6      "CreateTime": "2023-03-03T13:36:00.408Z",
7      "Severity": "High",
8      "StartTime": "2023-03-03T13:36:00.408Z",
9      "Status": "Event",
10     "Version": "2.0.3",
11     "Category": [
12       "Anomaly"
13     ]
14   },
15   "id": "608f0661-126c-497f-8054-51a7a4277b30"
16 }

```

Listing 1: Example of CADF alert format. The id field represents a unique identifier for the alert, and it is stored in the ATRS along with other security relevant information.

attack is successful, and the attacker is able to access a restricted area and tamper a measurement sensing device (a PMU in the proposed scenario). The CADF tool is able to promptly detect the attack, by correlating information on the failed login attempts, followed by the successful login, and the anomalous value detected from the PMU. Thanks to the features dedicated to Critical Infrastructures, the correlation features are graphically managed with rule-based logic. First, the login information is collected from the dedicated probe, parsed and forwarded to the correlation engine of the CADF. According to the implemented correlation logic, an alert is generated when more than a certain number of failed login attempts is detected, followed by at least a successful one from the same user, and the dedicated probe detects an anomalous value from the measuring device. All the information collected by the probes are displayed on a dedicated Dashboard, along with a brief description of the detected alerts. Once the alert is raised, all the security relevant data collected in the selected monitoring time is stored in the ATRS as shown in Section 3.2. Within the CADF, all the alerts are converted to IDMEFv2 as previously mentioned. An example of alert for the proposed use case is shown in Listing 1, where geolocalization and other sensitive information regarding the source of the attack and the target have been omitted.

Further details about testing and validation of the CADF can be found in Chapter 5. In particular, a novel approach to enhance the CADF correlation rules with ML has been

implemented and tested, with promising experimental results.

Chapter 5

The Hybrid Cyber-Attack Detection Framework

Due to the imperative need to enhance traditional-based security monitoring to face the ever evolving nature of attacks, part of present research focused on the enhancement of the CADF with the use of ML techniques. In particular, an IDS dataset [80] has been employed to support the definition of highly accurate detection rules. The CICIDS2017 is a well-recognised benchmark dataset designed for evaluating IDS against sophisticated and evolving network attacks. The choice of this dataset was motivated by its careful addressing of the shortcomings of other datasets, which suffer from outdated information, lack of diversity, and anonymization of critical data. It is noteworthy that there's a broad spectrum of attacks that CIs may face, such as attacks targeting the disruption of services by causing malfunctions in sensors or actuators, as well as attacks targeting domain-specific protocols. While the presented approach takes a specific attack in consideration, the methodology for the definition of detection rules can be generalized and applied to a wider range of scenarios. In the following, tests against DDoS attacks are reported, focusing on ensuring Availability. The focus on this kind of attack reflects a pervasive and persistent threat. In fact, According to the latest ENISA threat landscape, there has been a “significant rise on attacks against availability, particularly DDoS, with the ongoing war being the main reason behind such attacks” [81].

The proposed approach can be schematised as shown in Figure 5.1.

Essential data preprocessing steps have been conducted to ensure the quality and suitability of the dataset. This included handling missing values, removing duplicates, and addressing class imbalance issues through techniques like Synthetic Minority Over-sampling Technique (SMOTE) [82]. To streamline the analysis and reduce dimensionality, the SelectKBest feature selection method from the scikit-learn library has been employed.

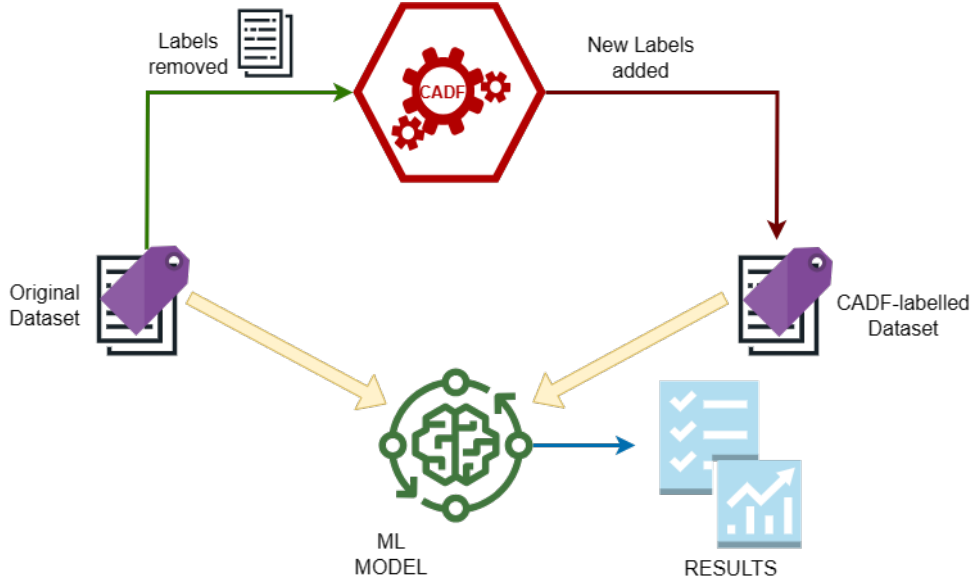


Figure 5.1: Proposed approach for Hybrid CADF. A ML classifier is used to evaluate the accuracy of the CADF rules, and to define more advanced discriminatory criteria based on the analysis of results and hidden relationship between features.

SelectKBest utilizes univariate statistical tests, such as ANOVA F-value, to identify the most relevant features for the analysis. The set of selected features is shown in Table 5.1. Afterwards, the dataset was employed to simulate real-time network traffic. For this scope, the last column containing the labels was removed, while the remaining ones are converted in JSON keys, with the rows representing the values. The JSON entries were then read by a simulated network probe, that shipped data to the CADF through a Kafka producer. Static correlation rules were created to discriminate between regular and anomalous traffic. As a result of the correlation rules, the original samples were labelled as malicious or benign according to the pre-defined criteria. This procedure formulated novel datasets, which are identical to the original one, with the exception of the labels attributed by the CADF correlation rule. The core concept is to compare the CADF-labelled datasets with the original dataset ground truth to evaluate the effectiveness of the CADF rules. Afterwards, ARM and xAI were employed to analyze in depth the datasets' features and extract relevant discrimination criteria for the CADF. Finally, the CADF-labelled datasets created with the new rules were also compared with the ground truth.

Table 5.1: Most relevant features selected for the experiment.

Feature	Description
ACK Flag Count	It represents the number of packets with the ACK (Acknowledgment) flag set in the network flow.
Flow Duration	It refers to the time duration of a network flow.
Idle Mean	It denotes the average time period of inactivity between successive packets in a flow.
Min Packet Length	It represents the minimum length of packets observed in the network flow. It can be indicative of the smallest unit of data transmitted in the communication.
Bwd Packet Length Mean	It stands for the mean packet length observed in the backward direction (from destination to source) in the flow. It provides direction-specific insights.
min_seg_size_forward	This feature represents the minimum TCP segment size observed in the forward direction (from source to destination) during the communication.
Destination Port	This feature indicates the port number used by the destination in the network flow. It can help identifying specific services or applications involved in the communication.
Packet Length Mean	It represents the average length of packets in the flow, offering insights into the typical packet size during the communication.
URG Flag Count	It refers to the number of packets with the URG (Urgent) flag set in the flow, indicating data that requires immediate attention.
Fwd Packet Length Mean	It represents the average length of packets in the forward direction (from source to destination) in the flow.
RST Flag Count	It represents the number of packets with the RST (Reset) flag set in the network flow. The RST flag can be significant in detecting abnormal behaviour.
SYN Flag Count	SYN Flag Count denotes the number of packets with the SYN (Synchronize) flag set in the flow, crucial in establishing a TCP connection.
Total Backward Packets	This feature represent the total number of packets transmitted in the backward direction (from destination to source) during the flow.
Active Mean	This feature represents the average time duration of activity within a flow, providing insights into the active periods of communication.

5.1 Rule Discovery

The applied method is formalised as follows. Let X represent the set of features in the original dataset D , and let $y = \{DDoS, BENIGN\}$ be the corresponding labels. The aim is to identify x_{rule} and use it as discrimination criteria between DDoS and BENIGN samples. As shown in Equation 5.1, to minimize the number of mislabelled samples, the difference between the original set of labels and the CADF-labelled one must be minimized.

$$x_{rule} \in X : \min_{x_{rule}} |y_{CADF} \setminus y| \quad (5.1)$$

5.1.1 CADF Rules

Within the present research, two different correlation rules have been generated. The correlation criteria have been defined through a linear correlation analysis between the dataset features and the DDoS label. Let C be the correlation index and x_i be the i th feature in the dataset. The linear correlation analysis selects the feature x_i with the highest correlation index, as shown in Equation 5.2:

$$j = \operatorname{argmax}_i (C(f_i, DDoS)) \quad (5.2)$$

After this analysis, the *FlowDuration* and *BwdPacketLengthMean* features have been selected and used as foundation to build discrimination criteria, as shown in the following. In Equation 5.4, the feature *BwdPacketLengthMean* is represented as *BPLengthMean* for the sake of brevity.

$$y_{cadf} = \begin{cases} DDoS & \text{if } FlowDuration \geq T_{FlowDuration} \\ BENIGN & \text{otherwise} \end{cases} \quad (5.3)$$

$$y_{cadf} = \begin{cases} DDoS & \text{if } BPLengthMean \geq T_{BPLengthMean} \\ BENIGN & \text{otherwise} \end{cases} \quad (5.4)$$

5.1.2 ARM Rules

ARM is a powerful data mining technique widely utilized in various domains, including cybersecurity, for discovering hidden patterns and relationships within large datasets. In the context of this research, ARM plays a crucial role in enhancing the discriminatory criteria of traditional rule-based CADF systems. The APRIORI algorithm has been applied to the considered dataset D to mine the most correlated features with the target variable (DDoS), and discover hidden relationships between features. For D , an interesting rule

has been found between the following features: *BwdPacketLengthMean*, *FwdPacketLengthMean*, and *InitWinBytesForward*. A set of CADF-labelled datasets, D_{arm} , has been created according to the refined rules defined after the association rule mining analysis. In the equations, the features *BwdPacketLengthMean* and *FwdPacketLengthMean* are represented as *BPLengthMean* and *FPLengthMean* respectively, for the sake of brevity.

$$y_{arm} = \begin{cases} DDoS & \text{if } BPLengthMean \geq TM \times FPLengthMean \\ BENIGN & \text{otherwise} \end{cases} \quad (5.5)$$

$$y_{arm} = \begin{cases} DDoS & \text{if } InitWinBytesForward = 256 \\ & \text{or} \\ & BPLengthMean \geq TM \times FPLengthMean \\ BENIGN & \text{otherwise} \end{cases} \quad (5.6)$$

It has been observed that, for the original dataset D , only DDoS instances had a specific value for *InitWinBytesForward*. As suggested by the association rules, this has been a key feature for a highly accurate detection.

5.1.3 xAI Rules

Within AI, xAI has emerged as a critical area of focus, with the aim to provide a deeper understanding of the logic behind ML models' logic. In the present research, a third set of enhanced rules is mined through SHapley Additive exPlanations (SHAP) and ANCHOR. All the rules from both sets have been tested using a ML classifier. The application of xAI on the ML classifier for the selected dataset has revealed a set of complex nested rules. All the extracted rules are used for binary classification, dividing network traffic into two classes: *Class* : 0 (benign) and *Class* : 1, which represents DDoS attacks. A striking commonality across all the trees is that the majority of paths lead to the classification of traffic as benign (*Class* : 0). This suggests that the primary purpose of these trees is to identify benign or non-malicious traffic effectively. The SHAP values have been extracted and analyzed, leading to the following CADF rule (Equation 5.7). The features with highest SHAP values has been considered and employed in the definition of a discriminatory criteria.

$$y_{xAI} = \left\{ \begin{array}{ll} \textit{BENIGN} & \textit{if } \textit{DestPort} \in \textit{Whitelist} \\ \textit{DDoS} & \textit{if } \textit{DestPort} \in \textit{Blacklist} \\ & \textit{or} \\ & \textit{TotBWDP} \leq T_{TPL} \\ & \textit{or} \\ & \textit{FlowDuration} > T_{FlowDuration} \\ \textit{BENIGN} & \textit{otherwise} \end{array} \right. \quad (5.7)$$

Finally, another rule has been derived using explainability features provided by ANCHOR. The rule is formalized in Equation 5.8:

$$y_{xAI} = \left\{ \begin{array}{ll} \textit{BENIGN} & \textit{if } a \geq \textit{FPLengthMean} > b \\ \textit{DDoS} & \textit{if } \textit{BPLengthMean} \geq T_1 \\ & \textit{or} \\ & \textit{FPLengthMean} < T_2 \\ & \textit{or} \\ & \textit{PLengthMean} > T_{PL} \\ \textit{BENIGN} & \textit{otherwise} \end{array} \right. \quad (5.8)$$

5.2 Parameter Settings

To conduct the experiments and implement the proposed methodology effectively, several parameters needed to be defined. The present section outlines the key parameter settings used throughout the research.

5.2.1 Feature Selection Parameters

For the dimensionality reduction, the datasets were processed with scikit-learn's SelectKBest, and the individual scores for each feature were analyzed to identify the most relevant features. SelectKBest performs a univariate statistical test using the Analysis of variance (ANOVA) F-value between the labels and the features. The top 14 features were selected. This value was chosen after observing a significant drop in feature scores beyond this point, indicating that these 14 features were the most relevant. The correla-

tion between features has also been studied to avoid redundant features and only select the most representative ones.

5.2.2 Association Rule Mining Parameters

The APRIORI algorithm has been employed for discovering association rules in the considered datasets. The Minimum Support Threshold controls the minimum frequency or occurrence of an itemset in the dataset for it to be considered in the rule mining process. The authors experimented with different support thresholds, including 0.1, 0.05, and 0.01, to observe the impact of varying support levels. The Minimum Confidence Threshold determines the minimum level of confidence required for an association rule to be considered relevant. Different confidence thresholds have been tested, such as 0.7, 0.8, and 0.9, to assess the impact on rule discovery.

5.2.3 Rules Parameters

For defining correlation rules, the threshold values were derived from the statistical properties of the selected features and the discovered criteria. In Equation 5.3 and Equation 5.4, the thresholds $T_{FlowDuration}$ and $T_{BwdPacketLengthMean}$ have been set equal to the mean value of the selected feature for all the samples of the original dataset. To define a suitable value for the TM parameter shown in Equation 5.5 and 5.6, multiple approaches have been considered. Ultimately, the optimal value has been obtained by calculating the average $BwdPacketLengthMean$ to

$FwdPacketLengthMean$ ratio for DDoS instances. This value was set to optimize the discrimination between DDoS and benign traffic. In Equation 5.7), the threshold T_{TPL} used for the $TotalBackwardPackets$ feature has been set equal to the mean value of the feature for the entire dataset. The threshold for $FlowDuration$ is the same employed in Equation 5.3. The *Whitelist* and *Blacklist* have been derived checking the exclusive values of $DestinationPort$ for BENIGN and DDoS labels, respectively. The thresholds T_1 and T_2 have been obtained as shown in Equation 5.9.

$$T = k \cdot \sigma \quad (5.9)$$

Where σ is defined as shown in Equation 5.10, considering individual standard deviations for the entire dataset, DDoS, and BENIGN instances. The k parameter represent the coefficient used to adjust the thresholds based on standard deviation. Its value has been determined through an empirical trial-and-error method.

$$\sigma = \sqrt{\frac{(\sigma_{total})^2 + (\sigma_{DDoS})^2 + (\sigma_{BENIGN})^2}{3}} \quad (5.10)$$

Table 5.2: Summary of classification reports for the original CADF rules.

Correlation Rules	Precision		Recall		F1-score		Accuracy
	BENIGN	DDoS	BENIGN	DDoS	BENIGN	DDoS	
Eq. 5.3	0.79	0.62	0.46	0.88	0.58	0.73	0.67
Eq. 5.4	0.73	0.98	0.98	0.63	0.84	0.76	0.77

Table 5.3: Summary of classification reports for the ARM rules.

Correlation Rules	Precision		Recall		F1-score		Accuracy
	BENIGN	DDoS	BENIGN	DDoS	BENIGN	DDoS	
Eq. 5.5	0.73	0.99	1	0.63	0.84	0.77	0.81
Eq. 5.6	1	0.99	0.99	1	0.99	0.99	0.99

The same logic has been applied considering *BwdPacketLengthMean* and *FwdPacketLengthMean* respectively for T_1 and T_2 . The parameters a and b have been set equal to the minimum and maximum values of the feature for BENIGN samples, respectively.

5.3 Experimental Result

The results of the experiments are summarized in Table 5.2, Table 5.3, and Table 5.4. The tables show a summary of the classification report based on Precision (5.11), Recall (5.12), F1-Score (5.13), and Accuracy (5.14). In the following equations, for the sake of brevity, True Positive (TP), True Negative (TN), False Positive (FP) and False Negative (FN) are denoted using the acronyms.

$$\text{Precision} = \frac{\text{TP}}{\text{TP} + \text{FP}} \quad (5.11)$$

$$\text{Recall} = \frac{\text{TP}}{\text{TP} + \text{FN}} \quad (5.12)$$

$$\text{F1 Score} = 2 \times \frac{\text{Precision} \times \text{Recall}}{\text{Precision} + \text{Recall}} \quad (5.13)$$

$$\text{Accuracy} = \frac{\text{Number of Correct Predictions}}{\text{Total Number of Predictions}} \quad (5.14)$$

As shown in the Tables, the different rules implemented present varying degrees of performance. Equation 5.4 stands out in comparison to Equation 5.3 with higher Precision, Recall, F1-Score, and Accuracy. It can be also noticed that while Equation 5.4 exhibits high Precision, it compromises on Recall. This suggests a potential trade-off between pre-

Table 5.4: Summary of classification reports for the xAI rules.

Correlation Rules	Precision		Recall		F1-score		Accuracy
	BENIGN	DDoS	BENIGN	DDoS	BENIGN	DDoS	
Eq. 5.7	1	0.93	0.92	1	0.96	0.96	0.96
Eq. 5.8	1	0.96	0.96	1	0.98	0.98	0.98

cision and recall in the original CADF rules. The performance metrics of the both rules, while providing a baseline for correlation, reveal the need for further refinement. The system's ability to detect DDoS attacks can be enhanced, and this realization prompts the need of more advanced correlation techniques. The ARM approach, as depicted in Table 5.3, demonstrates a notable advancement in the system's discriminatory power. ARM has unearthed association rules that significantly contribute to the identification of DDoS traffic. In particular, Equation 5.6 exhibits outstanding Precision, Recall, F1-Score, and Accuracy, indicating a near-perfect performance in distinguishing between benign and malicious instances. The balance between Precision and Recall indicates a robust ability to correctly identify DDoS traffic without compromising on FN or FP. The effectiveness of ARM rules can be attributed to their ability to capture intricate relationships and dependencies within the network traffic data. The discovered patterns empower the intrusion detection system to make more informed decisions, leading to a substantial improvement in its overall performance. The xAI approach, represented in Table 5.4, offers a unique perspective on correlation rules. The interpretability of the rules derived through xAI techniques enhances the system's transparency and facilitates a deeper understanding of the decision-making process. Both Equation 5.7 and Equation 5.8 showcase near-perfect Precision, Recall, F1-Score, and Accuracy. Additionally. Both xAI rules strike a balance between Precision and Recall, showcasing the potential of xAI techniques to offer a comprehensive solution. the xAI rules provide human-understandable insights into the features and patterns contributing to the decision-making process. The comparison of the three approaches reveals a progressive refinement in the system's performance. The original CADF rules provide a baseline, while the ARM and xAI approaches contribute advanced correlation rules that significantly enhance the system's ability to discern between benign and malicious traffic.

Chapter 6

Application Domains and Use Cases

As discussed in Chapter 3 and 4, the ATRS and CADF have been integrated to provide an inclusive solution for Security Monitoring in CIs. This chapter seeks to enhance the validation and test previously presented by exploring the areas of applicability for the proposed framework in real-time reliability and security monitoring in critical systems. These areas encompass various and complementary requirements that contribute to the overall system protection and continuous operation. For each area, possible use cases of interest are identified.

6.1 Anomaly Detection

Anomaly detection techniques are needed for identifying abnormal system behaviours that could indicate potential faults or security breaches. In the context of real-time reliability and security monitoring in critical systems, there are various approaches that can be employed. Statistical methods, such as outlier detection and time-series analysis, can help identify deviations from normal patterns. ML algorithms, such as clustering, classification, and anomaly-based models, can learn patterns from historical data and detect anomalies in real time. Rule-based systems can define specific rules and thresholds to identify deviations from expected behaviour. The selection of appropriate anomaly detection algorithms based on the specific characteristics of the critical system is crucial. Different systems may exhibit different patterns and behaviours, requiring tailored algorithms that can accurately identify anomalies within that particular context. This involves understanding the unique features, data characteristics, and expected normal behaviours of the system to choose algorithms that are most suitable for detecting anomalies in that specific environment. Critical systems often generate and process a large volume of data in real time. Ensuring that anomaly detection algorithms can handle this high data throughput is essential for the timely detection of anomalies. Handling complex

and dynamic system behaviour is a significant challenge in anomaly detection. Critical systems can exhibit intricate and evolving behaviours, making it difficult to distinguish anomalies from legitimate variations. An effective anomaly detection system should be capable of understanding and modelling this complex system behaviour to avoid false positives (incorrectly flagging normal behaviour as anomalies) and false negatives (failing to detect actual anomalies). Techniques such as ML, pattern recognition, and anomaly-based models can be employed to capture and adapt to the dynamic behaviour of the system. Lastly, adaptive anomaly detection methods are essential to cope with changing system conditions and evolving threats. Critical systems are subject to various external influences and may experience shifts in normal behaviour over time. Moreover, new and sophisticated threats may emerge that require the detection system to adapt and learn from these evolving patterns. Anomaly detection algorithms should be designed to continuously monitor and learn from the system's behaviour, adjusting their detection thresholds and strategies accordingly to effectively detect anomalies in the face of evolving conditions and threats.

6.1.1 Running Example

A specific use case example where anomaly detection is valuable is in identifying abnormal energy consumption patterns that could indicate power theft or malfunctioning equipment. In a power grid system, there is a vast network of interconnected devices, such as transformers, meters, and distribution lines, responsible for delivering electricity to consumers. These devices generate a massive amount of data, including real-time energy consumption readings. By continuously monitoring this data, it is possible to identify unusual consumption patterns that deviate from the expected behaviour. Anomaly detection in this context involves comparing the current energy consumption data with historical patterns. This comparison allows for the identification of deviations or anomalies that may indicate suspicious activities or system faults. For example, a sudden spike or drop in energy consumption that is inconsistent with normal usage patterns could indicate power theft or the presence of malfunctioning equipment. When an anomaly is detected, appropriate actions can be taken to investigate and address the issue. Depending on the severity and nature of the anomaly, different response mechanisms can be triggered. For instance, if power theft is suspected, further investigations can be initiated to identify the source and take necessary legal actions. In the case of malfunctioning equipment, maintenance or repair activities can be scheduled to ensure the integrity and reliability of the power grid system.

6.2 Intrusion Detection

IDSs are vital for protecting critical systems against security threats. Different types of IDS can be employed, including network-based, host-based, and behaviour-based approaches. Network-based IDS monitor network traffic to identify suspicious activities, such as port scanning or unauthorized access attempts. Host-based IDS focus on monitoring activities on individual hosts, detecting anomalies in file systems, user behaviour, or system configurations. Behaviour-based IDS analyze system behavior and user activities to identify deviations from normal behaviour, such as privilege escalation or unusual data access patterns. The integration of multiple IDS types allows for a layered defence approach, increasing the chances of detecting and preventing a wide range of intrusions. By combining network-based, host-based, and behaviour-based IDS, the system can monitor and analyze various dimensions of system behaviour, network traffic, and user activities to provide comprehensive security coverage. Furthermore, timeliness is crucial in intrusion detection. The IDS should be capable of analyzing network traffic and monitoring host activities in real time to quickly identify and respond to potential intrusions. The real-time analysis enables immediate detection and mitigation of security threats, minimizing the potential impact on system integrity and confidentiality. Attack techniques constantly evolve, requiring IDS to adapt and update their detection methods. Adaptive detection techniques leverage ML, anomaly detection, and behaviour analysis to dynamically learn and detect new attack patterns. By continuously updating their detection capabilities, IDS can effectively detect emerging threats and prevent successful intrusions. Efficient management of false positives and negatives to minimize the impact on system performance and usability is also a critical aspect. False positives and negatives can affect the usability and performance of an IDS. False positives occur when legitimate activities are incorrectly flagged as intrusions, while false negatives occur when actual intrusions go undetected. Efficient management of these errors involves fine-tuning detection algorithms, adjusting thresholds, and leveraging advanced techniques such as ML to minimize false positives and negatives. This ensures that legitimate activities are not unnecessarily disrupted, while genuine security threats are promptly identified.

6.2.1 Running Example

In a critical healthcare system, a network-based IDS can be employed to monitor incoming and outgoing network traffic to detect any unauthorized attempts to access patient records or sensitive medical information. The IDS continuously analyzes network packets and compares them to known attack signatures or behavioural patterns. For instance, the IDS can detect port scanning activities, unauthorized access attempts, or data ex-

filtration. By comparing network traffic to known attack patterns, the IDS can identify potential security breaches and trigger immediate responses to mitigate the risks. The IDS raises alerts or notifications to the system administrators or security personnel, notifying them of the detected intrusion attempts. The healthcare system's security team can then investigate the incident further, take appropriate actions to mitigate the threat and ensure the integrity and confidentiality of patient data. The network-based IDS serves as a crucial component in safeguarding the healthcare system against unauthorized access and potential data breaches, protecting the privacy and well-being of patients.

6.3 System Recovery

Efficient system recovery mechanisms are essential in critical systems to minimize downtime and restore normal operations. Various strategies can be employed, including fault tolerance techniques, backup and restoration mechanisms, and reconfiguration approaches. Fault tolerance techniques, such as redundancy and error correction codes, ensure the system can continue operating even in the presence of failures. Backup and restoration mechanisms involve regularly creating backups of critical system components and data, allowing for rapid recovery in case of failures. Reconfiguration approaches involve dynamically adjusting the system configuration to maintain functionality in the presence of faults or security incidents. Determining the appropriate level of fault tolerance involves assessing the criticality of the system components and the potential impact of failures. Critical systems may require higher levels of fault tolerance to ensure continuous operation, while non-critical components can have lower levels of redundancy. However, cost constraints must also be considered to optimize the allocation of resources. Balancing the criticality of system components with cost constraints enables the implementation of an optimal fault tolerance strategy. Efficient backup and restoration mechanisms are crucial for minimizing recovery time and resource usage. Regularly creating backups of critical system components and data ensures that in the event of a failure, the system can be restored quickly and effectively. Efficient backup mechanisms employ strategies such as incremental backups, differential backups, or distributed backup solutions to minimize the time and resources required for recovery. By prioritizing critical data and system components, recovery can be prioritized, reducing the impact of downtime. Dynamic reconfiguration approaches enable the system to adapt to changing conditions, including failures or security incidents, without interrupting critical operations. These approaches involve adjusting system configurations, reallocating resources, or activating redundant components in real-time to maintain functionality. By dynamically reconfiguring the system, it can continue to operate despite failures or security incidents, minimizing dis-

ruptions and ensuring uninterrupted operation. Integrating system recovery mechanisms within the real-time monitoring architecture enables rapid response to failures or security incidents. By closely coupling system recovery mechanisms with real-time monitoring, the system can quickly detect and respond to failures or security breaches. This integration allows for immediate actions to be taken, such as triggering backup restoration, activating redundant components, or initiating incident response procedures. The real-time monitoring architecture provides the necessary information and alerts to initiate timely and effective system recovery measures, reducing the impact of failures or security incidents.

6.3.1 Running Example

In a critical transportation system, system recovery mechanisms play a crucial role in minimizing the impact of hardware failures and ensuring uninterrupted operation. The transportation system relies on various hardware components such as servers, communication links, and other critical infrastructure to facilitate smooth operation. However, hardware failures can occur unexpectedly, leading to disruptions in services and potential safety risks. To mitigate these risks, system recovery mechanisms are employed. In the event of a hardware failure in the primary server, the system can automatically switch to the backup server without any noticeable service interruptions. This seamless transition ensures that critical transportation services, such as scheduling, ticketing, or traffic management, can continue to function without disruption. Additionally, redundant communication links can be established to ensure continuous connectivity between different components of the transportation system. These redundant links provide alternative pathways for data transmission, allowing the system to maintain communication even if one of the links fails. By automatically rerouting the data flow through the available paths, the transportation system can avoid communication breakdowns and ensure the timely exchange of information. The integration of system recovery mechanisms within the critical transportation system's architecture enables rapid response to hardware failures. Once a failure is identified, the system recovery mechanisms are triggered, allowing for immediate action. The monitoring system provides alerts and notifications to the operations team, enabling them to respond promptly and initiate the necessary recovery procedures.

6.4 Response Mechanisms

Prompt response mechanisms are essential in mitigating the impact of detected faults or security incidents. Various response mechanisms can be employed, including automated actions, alert notifications, incident response procedures, and collaboration with external security entities. Automated actions can involve automatic reconfiguration of the system,

isolation of compromised components, or dynamic adjustment of security policies. Alert notifications can be sent to system administrators or security personnel to ensure immediate awareness of the detected incidents. Incident response procedures define the steps to be followed in case of a security incident, including incident investigation, containment, eradication, and recovery. Collaboration with external security entities, such as security operations centres or law enforcement agencies, can provide additional expertise and resources to address complex or large-scale incidents. Automated response mechanisms play a crucial role in mitigating the impact of detected security incidents. However, it is important to strike a balance between the need for immediate action and the risk of false positives. False positives occur when an alert or detection incorrectly identifies an event as a security incident. Designing automated response mechanisms requires careful consideration to avoid unnecessary disruptions caused by false positives while ensuring timely action against genuine security threats. This involves implementing intelligent algorithms and decision-making processes that accurately assess the severity and validity of each detected incident before triggering automated responses. Efficient incident response procedures are essential to ensure a systematic and effective response to security incidents. These procedures define the steps and actions to be taken when a security incident is detected, including incident investigation, containment, eradication, and recovery. Well-defined and documented incident response procedures enable security teams to respond swiftly and effectively, minimizing the impact of incidents and facilitating a rapid return to normal operations. Efficient procedures consider factors such as incident prioritization, roles and responsibilities of team members, communication protocols, and the use of appropriate tools and technologies to support incident response efforts. To enable timely and coordinated actions, it is crucial to integrate response mechanisms within the real-time monitoring architecture. The architecture should facilitate seamless communication between the monitoring systems, automated response mechanisms, and the incident response team. The integration allows for the automatic transfer of relevant incident information from the monitoring systems to the response mechanisms, enabling immediate actions based on predefined rules or triggering manual intervention by the incident response team. Real-time monitoring ensures that incidents are detected promptly, and the integrated response mechanisms enable swift and coordinated responses to mitigate the impact of security incidents. Collaboration and information sharing with external security entities, such as security operations centres or law enforcement agencies, can significantly enhance incident response capabilities. Establishing partnerships and communication channels with external entities allows for the exchange of threat intelligence, best practices, and expertise. This collaboration enables a more comprehensive understanding of emerging threats, access to additional resources for incident investiga-

tion and analysis, and the ability to coordinate responses to large-scale or sophisticated security incidents. By leveraging the collective knowledge and capabilities of external security entities, incident response teams can improve their incident detection, analysis, and mitigation capabilities, enhancing the overall effectiveness of the response process.

6.4.1 Running Example

In a critical financial system, response mechanisms play a vital role in mitigating the impact of a detected security breach. When a security breach is detected, various response mechanisms can be employed to ensure the security and integrity of the financial system and its sensitive data. Upon detecting a security breach, automated actions can be initiated to minimize further damage. For example, the compromised user account can be immediately blocked to prevent unauthorized access. Isolating the affected system component, such as a compromised server or network segment, helps contain the breach and prevents it from spreading to other parts of the system. Additionally, automated responses may trigger a forensic analysis process, allowing security teams to investigate the breach and identify the extent of the compromise. Forensic analysis helps gather evidence, understand the attack vectors, and determine the potential impact on the financial system. Simultaneously, alert notifications are sent to the security team to ensure immediate attention and initiation of incident response procedures. These notifications provide essential details about the detected security breach, including the nature of the incident, affected system components, and potential risks. Alert notifications enable the incident response team to promptly assess the situation, allocate resources, and initiate the appropriate incident response procedures to address the security breach effectively. In complex security breaches or cases where specialized expertise is required, collaboration with external security entities can be invaluable. External entities may include security operations centres, computer emergency response teams (CERTs), or law enforcement agencies. Collaboration allows for additional expertise in forensic analysis, investigation, and legal actions if necessary. External entities can bring specialized tools, knowledge, and resources to support the incident response efforts, ensuring a comprehensive and thorough response to the security breach.

Chapter 7

Conclusion

In a world where CIs are increasingly data-dependent and interconnected, the need for advanced security strategies and solutions cannot be overstated. Detecting and responding to attacks, preserving data integrity, and ensuring data traceability are vital components of safeguarding these critical systems. Throughout the present dissertation, the security challenges faced by CIs have been analyzed and discussed, with a major focus on the role of data in safeguarding such systems. Among the various key aspects, effective attack detection and data reliability and traceability methods have been taken into consideration in the course of this study. A literature review was undertaken to gain a comprehensive perspective on the state of Data Provenance in CIs, highlighting the importance of a transparent and tamper-resistant approach. The ATRS, leveraging Blockchain technology, has been developed to address this need: the framework has been designed by taking into account the findings of the review, and it has been tested and evaluated in a realistic scenario. Concurrently, the CADF was designed to address the need of detecting known and emerging cyber threats within CIs. The integration of the ATRS and CADF as an inclusive solution for CIs has been also accomplished: in the integrated framework, the instant detection of threats by CADF triggers the permanent storage of security relevant data in ATRS. This integrated approach has been demonstrated through two illustrative use cases, addressing cyber-attacks targeting data confidentiality and integrity. As the threat landscape continues to evolve, continuous monitoring and improvement of security capabilities are essential to adapt to new threats and attack patterns. Therefore, the CADF has been enhanced with ML to augment the precision of cyber threat detection to face the evolving nature of attacks in today's landscape. In particular, a novel approach for the definition of highly accurate detection rules for the CADF has been implemented and tested, focusing on threats against data availability, with promising experimental results. Finally, a variety of possible application domains and use cases is explored and discussed, to showcase the applicability of the proposed research to real-life scenarios.

Bibliography

- [1] Muhammad Sheeraz, Muhammad Arsalan Paracha, Mansoor Ul Haque, Muhammad Hanif Durad, Syed Muhammad Mohsin, Shahab S Band, and Amir Mosavi, “Effective security monitoring using efficient siem architecture,” *Hum.-Centric Comput. Inf. Sci.*, vol. 13, pp. 1–18, 2023.
- [2] European Commission, “Critical infrastructure,” https://ec.europa.eu/home-affairs/pages/page/critical-infrastructure_en.
- [3] European Commission, “A european strategy for data,” <https://digital-strategy.ec.europa.eu/en/policies/strategy-data>.
- [4] Oskars Podzins and Andrejs Romanovs, “Why siem is irreplaceable in a secure it environment?,” in *2019 Open Conference of Electrical, Electronic and Information Sciences (eStream)*, 2019, pp. 1–5.
- [5] Gustavo González-Granadillo, Susana González-Zarzosa, and Rodrigo Diaz, “Security information and event management (siem): analysis, trends, and usage in critical infrastructures,” *Sensors*, vol. 21, no. 14, pp. 4759, 2021.
- [6] Maximilian Rosenberg, Bettina Schneider, Christopher Scherb, and Petra Maria Asprion, “An adaptable approach for successful siem adoption in companies,” *arXiv preprint arXiv:2308.01065*, 2023.
- [7] Arnold Johnson, Kelley Dempsey, Ron Ross, Sarbari Gupta, Dennis Bailey, et al., “Guide for security-focused configuration management of information systems,” *NIST special publication*, vol. 800, no. 128, pp. 16–16, 2011.
- [8] Prof. Dr. Boris Otto, “Gaia-x and ids,” <https://doi.org/10.5281/zenodo.5675897>.
- [9] European Commission, “Digitalising the energy system - eu action plan,” .
- [10] Nathalie Baracaldo, Luis Angel D Bathen, Roqeeb O Ozugha, Robert Engel, Samir Tata, and Heiko Ludwig, “Securing data provenance in internet of things (iot) systems,” in *Service-Oriented Computing-ICSOC 2016 Workshops: ASOCA, ISyCC, BSCI, and Satellite Events, Banff, AB, Canada, October 10–13, 2016, Revised Selected Papers 14*. Springer, 2017, pp. 92–98.
- [11] Deepak Tosh, Sachin Shetty, Peter Foytik, Charles Kamhoua, and Laurent Njilla, “Cloudpos: A proof-of-stake consensus design for blockchain integrated cloud,” in *2018 IEEE 11th international conference on cloud computing (CLOUD)*. IEEE, 2018, pp. 302–309.
- [12] Rongyue Zheng, Jianlin Jiang, Xiaohan Hao, Wei Ren, Feng Xiong, and Yi Ren, “bcbim: A blockchain-based big data model for bim modification audit and provenance in mobile cloud,” *Mathematical Problems in Engineering*, vol. 2019, 2019.
- [13] Michael Mylrea and Sri Nikhil Gupta Gouriseti, “Blockchain: Next generation supply chain security for energy infrastructure and nerc critical infrastructure protection (cip) compliance,” *Resilience Week*, vol. 16, 2018.

- [14] Nachiket Tapas, Francesco Longo, Giovanni Merlino, and Antonio Puliafito, "Transparent, provenance-assured, and secure software-as-a-service," in *2019 IEEE 18th International Symposium on Network Computing and Applications (NCA)*. IEEE, 2019, pp. 1–8.
- [15] Javier Ramirez Zayas, Eduardo O'Neill, Maria A Seale, Alicia Ruvinsky, and Owen Eslinger, "An integrated blockchain approach for provenance of rotorcraft maintenance data," in *2020 IEEE Aerospace Conference*. IEEE, 2020, pp. 1–8.
- [16] Xueping Liang, Sachin S Shetty, Deepak Tosh, Laurent Njilla, Charles A Kamhoua, and Kevin Kwiat, "Provchain: Blockchain-based cloud data provenance," *Blockchain for Distributed Systems Security*, vol. 69, 2019.
- [17] Cristina Alcaraz, Juan E Rubio, and Javier Lopez, "Blockchain-assisted access for federated smart grid domains: Coupling and features," *Journal of Parallel and Distributed Computing*, vol. 144, pp. 124–135, 2020.
- [18] Davy Preuveneers, Wouter Joosen, Jorge Bernal Bernabe, and Antonio Skarmeta, "Distributed security framework for reliable threat intelligence sharing," *Security and Communication Networks*, vol. 2020, 2020.
- [19] Randhir Kumar and Rakesh Tripathi, "Data provenance and access control rules for ownership transfer using blockchain," *International Journal of Information Security and Privacy (IJISP)*, vol. 15, no. 2, pp. 87–112, 2021.
- [20] S Porkodi and D Kesavaraja, "Secure data provenance in internet of things using hybrid attribute based crypt technique," *Wireless Personal Communications*, vol. 118, no. 4, pp. 2821–2842, 2021.
- [21] Peng Zhu, Jian Hu, Yue Zhang, and Xiaotong Li, "A blockchain based solution for medication anti-counterfeiting and traceability," *IEEE Access*, vol. 8, pp. 184256–184272, 2020.
- [22] George C Polyzos and Nikos Fotiou, "Blockchain-assisted information distribution for the internet of things," in *2017 IEEE International Conference on Information Reuse and Integration (IRI)*. IEEE, 2017, pp. 75–78.
- [23] Vaggelis Malamas, Thomas Dasaklis, Panayiotis Kotzanikolaou, Mike Burmester, and Sokratis Katsikas, "A forensics-by-design management framework for medical devices based on blockchain," in *2019 IEEE world congress on services (SERVICES)*. IEEE, 2019, vol. 2642, pp. 35–40.
- [24] Md Nazmul Islam and Sandip Kundu, "Enabling ic traceability via blockchain pegged to embedded puf," *ACM Transactions on Design Automation of Electronic Systems (TODAES)*, vol. 24, no. 3, pp. 1–23, 2019.
- [25] Shubham Joshi, Shalini Stalin, Prashant Kumar Shukla, Piyush Kumar Shukla, Ruby Bhatt, Rajan Singh Bhadoria, and Basant Tiwari, "Unified authentication and access control for future mobile communication-based lightweight iot systems using blockchain," *Wireless Communications and Mobile Computing*, vol. 2021, 2021.
- [26] Salvatore D'Antonio and Federica Uccello, "Data provenance for healthcare: a blockchain-based approach," in *2022 IEEE 46th Annual Computers, Software, and Applications Conference (COMPSAC)*. IEEE, 2022, pp. 1655–1660.
- [27] Ahmad Musamih, Khaled Salah, Raja Jayaraman, Junaid Arshad, Mazin Debe, Yousof Al-Hammadi, and Samer Ellahham, "A blockchain-based approach for drug traceability in healthcare supply chain," *IEEE access*, vol. 9, pp. 9728–9743, 2021.
- [28] Rawya Mars, Jiddou Youssef, Saoussen Cheikhrouhou, and Mariem Turki, "Towards a blockchain-based approach to fight drugs counterfeit.," in *TACC*, 2021, pp. 197–208.
- [29] Ahmad Musamih, Raja Jayaraman, Khaled Salah, Haya R Hasan, Ibrar Yaqoob, and Yousof Al-Hammadi, "Blockchain-based solution for distribution and delivery of covid-19 vaccines," *Ieee Access*, vol. 9, pp. 71372–71387, 2021.

- [30] Vasileios Tsoukas, Anargyros Gkogkidis, Aikaterini Kampa, Georgios Spathoulas, and Athanasios Kakarountas, "Enhancing food supply chain security through the use of blockchain and tinyml," *Information*, vol. 13, no. 5, pp. 213, 2022.
- [31] Abdullah Ayub Khan, Asif Ali Laghari, Peng Li, Mazhar Ali Dootio, and Shahid Karim, "The collaborative role of blockchain, artificial intelligence, and industrial internet of things in digitalization of small and medium-size enterprises," *Scientific Reports*, vol. 13, no. 1, pp. 1656, 2023.
- [32] Zeeshan Pervez, Zaheer Khan, Abdul Ghafoor, and Kamran Soomro, "Signed: Smart city digital twin verifiable data framework," *IEEE Access*, 2023.
- [33] Saqib Ali, Guojun Wang, Md Zakirul Alam Bhuiyan, and Hai Jiang, "Secure data provenance in cloud-centric internet of things via blockchain smart contracts," in *2018 IEEE SmartWorld, Ubiquitous Intelligence & Computing, Advanced & Trusted Computing, Scalable Computing & Communications, Cloud & Big Data Computing, Internet of People and Smart City Innovation (SmartWorld/SCALCOM/UIC/ATC/CB-DCom/IOP/SCI)*. IEEE, 2018, pp. 991–998.
- [34] Hongyan Cui, Zunming Chen, Yu Xi, Hao Chen, and Jiawang Hao, "Iot data management and lineage traceability: A blockchain-based solution," in *2019 IEEE/CIC International Conference on Communications Workshops in China (ICCC Workshops)*. IEEE, 2019, pp. 239–244.
- [35] Nidish Vashistha, Muhammad Monir Hossain, Md Rakib Shahriar, Farimah Farahmandi, Fahim Rahman, and Mark M Tehranipoor, "echain: A blockchain-enabled ecosystem for electronic device authenticity verification," *IEEE Transactions on Consumer Electronics*, vol. 68, no. 1, pp. 23–37, 2021.
- [36] Narmeen Zakaria Bawany, Tehreem Qamar, Hira Tariq, and Saifullah Adnan, "Integrating healthcare services using blockchain-based telehealth framework," *IEEE Access*, vol. 10, pp. 36505–36517, 2022.
- [37] Yilin Sai, Clement Chu, Adrian Trinch, Antonella Sola, Shirley Shen, and Shiping Chen, "Uit-a universal identifier of things to bridge cyber and physical worlds," in *2022 IEEE International Conference on Blockchain and Cryptocurrency (ICBC)*. IEEE, 2022, pp. 1–3.
- [38] Eranga Bandara, Xueping Liang, Peter Foytik, and Sachin Shetty, "Blockchain and self-sovereign identity empowered cyber threat information sharing platform," in *2021 IEEE International Conference on Smart Computing (SMARTCOMP)*. IEEE, 2021, pp. 258–263.
- [39] Eranga Bandara, Deepak Tosh, Sachin Shetty, and Bheshaj Krishnappa, "Cyscpo-cyber supply chain provenance framework for risk management of energy delivery systems," in *2021 IEEE International Conference on Blockchain (Blockchain)*. IEEE, 2021, pp. 65–72.
- [40] Eranga Bandara, Sachin Shetty, Deepak Tosh, and Xueping Liang, "Vind: A blockchain-enabled supply chain provenance framework for energy delivery systems," *Frontiers in Blockchain*, vol. 4, 2021.
- [41] Adam Bates, Ben Mood, Masoud Valafar, and Kevin Butler, "Towards secure provenance-based access control in cloud environments," in *Proceedings of the third ACM conference on Data and application security and privacy*, 2013, pp. 277–284.
- [42] Hasan Ragib, Radu Sion, and Marianne Winslett, "The case of the fake picasso: Preventing history forgery with secure provenance," in *Fast*, vol. 9.
- [43] Mohammad M Bany Taha, Sivadon Chaisiri, and Ryan KL Ko, "Trusted tamper-evident data provenance," in *2015 IEEE Trustcom/bigdataase/ispa*. IEEE, 2015, vol. 1, pp. 646–653.
- [44] Dave Tian, Adam Bates, Kevin RB Butler, and Raju Rangaswami, "Provusb: Block-level provenance-based data protection for usb storage devices," in *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, 2016, pp. 242–253.

- [45] Ragib Hasan, Rasib Khan, Shams Zawoad, and Md Munirul Haque, "Woral: A witness oriented secure location provenance framework for mobile devices," *IEEE Transactions on Emerging Topics in Computing*, vol. 4, no. 1, pp. 128–141, 2015.
- [46] Jeffery Garae, Ryan KL Ko, and Mark Apperley, "A full-scale security visualization effectiveness measurement and presentation approach," in *2018 17th IEEE International Conference On Trust, Security And Privacy In Computing And Communications/12th IEEE International Conference On Big Data Science And Engineering (TrustCom/BigDataSE)*. IEEE, 2018, pp. 639–650.
- [47] Yulai Xie, Dan Feng, Xuelong Liao, and Leihua Qin, "Efficient monitoring and forensic analysis via accurate network-attached provenance collection with minimal storage overhead," *Digital Investigation*, vol. 26, pp. 19–28, 2018.
- [48] Muhammad Shoaib Siddiqui, Atiqur Rahman, and Adnan Nadeem, "Secure data provenance in iot network using bloom filters," *Procedia Computer Science*, vol. 163, pp. 190–197, 2019.
- [49] Nathalie Baracaldo, Bryant Chen, Heiko Ludwig, and Jaehoon Amir Safavi, "Mitigating poisoning attacks on machine learning models: A data provenance based approach," in *Proceedings of the 10th ACM Workshop on Artificial Intelligence and Security*, 2017, pp. 103–110.
- [50] Jamal Raiyn et al., "A survey of cyber attack detection strategies," *International Journal of Security and Its Applications*, vol. 8, no. 1, pp. 247–256, 2014.
- [51] Ansam Khraisat, Iqbal Gondal, Peter Vamplew, and Joarder Kamruzzaman, "Survey of intrusion detection systems: techniques, datasets and challenges," *Cybersecurity*, vol. 2, no. 1, pp. 1–22, 2019.
- [52] Marek Pawlicki, Aleksandra Pawlicka, Rafał Kozik, and Michał Choraś, "The survey and meta-analysis of the attacks, transgressions, countermeasures and security aspects common to the cloud, edge and iot," *Neurocomputing*, p. 126533, 2023.
- [53] Wenli Duo, MengChu Zhou, and Abdullah Abusorrah, "A survey of cyber attacks on cyber physical systems: Recent advances and challenges," *IEEE/CAA Journal of Automatica Sinica*, vol. 9, no. 5, pp. 784–800, 2022.
- [54] Yuchong Li and Qinghui Liu, "A comprehensive review study of cyber-attacks and cyber security; emerging trends and recent developments," *Energy Reports*, vol. 7, pp. 8176–8186, 2021.
- [55] Blessing Guembe, Ambrose Azeta, Sanjay Misra, Victor Chukwudi Osamor, Luis Fernandez-Sanz, and Vera Pospelova, "The emerging threat of ai-driven cyber attacks: A review," *Applied Artificial Intelligence*, vol. 36, no. 1, pp. 2037254, 2022.
- [56] Tao Ban, Takeshi Takahashi, Samuel Ndichu, and Daisuke Inoue, "Breaking alert fatigue: Ai-assisted siem framework for effective incident response," *Applied Sciences*, vol. 13, no. 11, pp. 6610, 2023.
- [57] Panagiotis Radoglou-Grammatikis, "Securecyber: An sdn-enabled siem for enhanced cybersecurity in the industrial internet of things," *IEEE COMSOC MMTTC Communications - Frontiers*, vol. 18, no. 2, pp. Mar 2023, 2023.
- [58] Hilala Alturkistani and Mohammed A El-Affendi, "Optimizing cybersecurity incident response decisions using deep reinforcement learning," *International Journal of Electrical and Computer Engineering*, vol. 12, no. 6, pp. 6768, 2022.
- [59] Yakub Kayode Saheed, Aremu Idris Abiodun, Sanjay Misra, Monica Kristiansen Holone, and Ricardo Colomo-Palacios, "A machine learning-based intrusion detection for detecting internet of things network attacks," *Alexandria Engineering Journal*, vol. 61, no. 12, pp. 9395–9409, 2022.
- [60] S Smys, Abul Basar, Haoxiang Wang, et al., "Hybrid intrusion detection system for internet of things (iot)," *Journal of ISMAC*, vol. 2, no. 04, pp. 190–199, 2020.

- [61] Taehoon Kim and Wooguil Pak, "Real-time network intrusion detection using deferred decision and hybrid classifier," *Future Generation Computer Systems*, vol. 132, pp. 51–66, 2022.
- [62] K. Narayana Rao, K. Venkata Rao, and Prasad Reddy P.V.G.D., "A hybrid intrusion detection system based on sparse autoencoder and deep neural network," *Computer Communications*, vol. 180, pp. 77–88, 2021.
- [63] Samed Al and Murat Dener, "Stl-hdl: A new hybrid network intrusion detection system for imbalanced dataset on big data environment," *Computers & Security*, vol. 110, pp. 102435, 2021.
- [64] Taehoon Kim and Wooguil Pak, "Robust network intrusion detection system based on machine-learning with early classification," *IEEE Access*, vol. 10, pp. 10754–10767, 2022.
- [65] Ihor Subach and Artem Mykytiuk, "Methodology of formation of fuzzy associative rules with weighted attributes from siem database for detection of cyber incidents in special information and communication systems," *Information Technology and Security, Vol. 11, Iss. 1 (20)*, 2023.
- [66] Martin Husák, Tomáš Bajtoš, Jaroslav Kašpar, Elias Bou-Harb, and Pavel Čeleda, "Predictive cyber situational awareness and personalized blacklisting: a sequential rule mining approach," *ACM Transactions on Management Information Systems (TMIS)*, vol. 11, no. 4, pp. 1–16, 2020.
- [67] S Sivanantham, V Mohanraj, Y Suresh, and J Senthilkumar, "Association rule mining frequent-pattern-based intrusion detection in network," *Computer Systems Science & Engineering*, vol. 44, no. 2, 2023.
- [68] Ping Lou, Guantong Lu, Xuemei Jiang, Zheng Xiao, Jiwei Hu, and Junwei Yan, "Cyber intrusion detection through association rule mining on multi-source logs," *Applied Intelligence*, vol. 51, pp. 4043–4057, 2021.
- [69] Muhammad Usama Islam, Md Mozaharul Mottalib, Mehedi Hassan, Zubair Ibne Alam, SM Zobaed, and Md Fazle Rabby, "The past, present, and prospective future of xai: A comprehensive review," *Explainable Artificial Intelligence for Cyber Security: Next Generation Artificial Intelligence*, pp. 1–29, 2022.
- [70] Carlos Mendes and Tatiane Nogueira Rios, "Explainable artificial intelligence and cybersecurity: A systematic literature review," *arXiv preprint arXiv:2303.01259*, 2023.
- [71] Cosmas Ifeanyi Nwakanma, Love Allen Chijioke Ahakonye, Judith Nkechinyere Njoku, Jacinta Chioma Odirichukwu, Stanley Adiele Okolie, Chinebuli Uzundu, Christiana Chidimma Ndubuisi Nweke, and Dong-Seong Kim, "Explainable artificial intelligence (xai) for intrusion detection and mitigation in intelligent connected vehicles: A review," *Applied Sciences*, vol. 13, no. 3, pp. 1252, 2023.
- [72] Shruti Patil, Vijayakumar Varadarajan, Siddiqui Mohd Mazhar, Abdulwodood Sahibzada, Nihal Ahmed, Onkar Sinha, Satish Kumar, Kailash Shaw, and Ketan Kotecha, "Explainable artificial intelligence for intrusion detection system," *Electronics*, vol. 11, no. 19, pp. 3079, 2022.
- [73] Basim Mahbooba, Mohan Timilsina, Radhya Sahal, and Martin Serrano, "Explainable artificial intelligence (xai) to enhance trust management in intrusion detection systems using decision tree model," *Complexity*, vol. 2021, pp. 1–11, 2021.
- [74] Satish Kumar Karna, Prakash Paudel, Ruby Saud, and Mohan Bhandari, "Explainable prediction of features contributing to intrusion detection using ml algorithms and lime," .
- [75] Chathuranga Sampath Kalutharage, Xiaodong Liu, Christos Chrysoulas, Nikolaos Pitropakis, and Pavlos Papadopoulos, "Explainable ai-based ddos attack identification method for iot networks," *Computers*, vol. 12, no. 2, pp. 32, 2023.
- [76] Qianru Zhou, Rongzhen Li, Lei Xu, Arumugam Nallanathan, Jian Yang, and Anmin Fu, "Towards explainable meta-learning for ddos detection," *arXiv preprint arXiv:2204.02255*, 2022.
- [77] European Parliament and Council of the European Union, "Regulation (EU) 2016/679 of the European Parliament and of the Council," .

-
- [78] Marten Sigwart, Michael Borkowski, Marco Peise, Stefan Schulte, and Stefan Tai, “Blockchain-based data provenance for the internet of things,” in *Proceedings of the 9th International Conference on the Internet of Things*, 2019, pp. 1–8.
 - [79] Luigi Coppolino, Salvatore D’Antonio, Federica Uccello, Anastasios Lyratzis, Constantinos Bakalis, Souzana Touloumtzi, and Ioannis Papoutsis, “Detection of radio frequency interference in satellite ground segments,” in *2023 IEEE International Conference on Cyber Security and Resilience (CSR)*, 2023, pp. 648–653.
 - [80] Iman Sharafaldin, Arash Habibi Lashkari, and Ali A Ghorbani, “Toward generating a new intrusion detection dataset and intrusion traffic characterization,” *ICISSp*, vol. 1, pp. 108–116, 2018.
 - [81] Claudio Ardagna, Stephen Corbiaux, Koen Van Impe, and Andreas Sfakianaki, “Enisa threat landscape 2022,” .
 - [82] Nitesh V Chawla, Kevin W Bowyer, Lawrence O Hall, and W Philip Kegelmeyer, “Smote: synthetic minority over-sampling technique,” *Journal of artificial intelligence research*, vol. 16, pp. 321–357, 2002.

List of Publications

D'Antonio S, Uccello F. Data Provenance for healthcare: a blockchain-based approach. In 2022 IEEE 46th Annual Computers, Software, and Applications Conference (COMPSAC) 2022 Jun 27 (pp. 1655-1660). IEEE.

D'Antonio S, Nardone R., Nicola R., Uccello F. A Tamper-Resistant Storage Framework for Smart Grid security. In 2023 IEEE 31st Euromicro International Conference on Parallel, Distributed, and Network-Based Processing (PDP) 2023 March 1 (pp. 100-103). IEEE.

Coppolino L., D'Antonio S, Uccello F., Lyratzis A., Bakalis C., Touloumtzi S., Papoutsis I. Detection of radio frequency interference in Satellite Ground Segments. In 2023 IEEE International Conference on Cyber Security and Resilience (CSR) 2023 July 31 (pp. 648-653). IEEE.

Coppolino L., D'Antonio S, Mazzeo G., Nardone R., Romano L., Uccello F., Enhancing the Critical Infrastructure Security with Data Provenance: a Systematic Literature Review. [submitted to Computers & Security]

Uccello F., Pawlicki M., D'Antonio S., Kozik R., and Choras M. (2023). "Effective Rules for a Rule-Based SIEM System in Detecting DoS Attacks: An Association Rule Mining Approach." In International Conference on Applied Intelligence. Springer-Nature series: Computer and Information Science (CCIS, volume 2015).

Uccello, F., Pawlicki, M., D'Antonio, S., Kozik, R., and Choras, M. "Towards Hybrid NIDS: Combining rule-based SIEM with AI-based intrusion detectors" In International Conference on Advances In Computing Research (ACR)

Uccello, F., Pawlicki, M., D'Antonio, S., Kozik, R., and Choras, M. "An Innovative Approach to Real-Time Concept Drift Detection in Network Security" In International Conference on Emerging Internet, Data & Web Technologies (EIDWT)

Uccello, F., Pawlicki, M., D'Antonio, S., Kozik, R., and Choras, M. "A novel approach to the use of explainability to mine network intrusion detection rules" In Asian Conference on Intelligent Information and Database Systems (ACIIDS)